



كلية العلوم
والتقنيات - مراكش
FACULTÉ DES SCIENCES
ET TECHNIQUES - MARRAKECH



FACULTÉ DES SCIENCES ET TECHNIQUES
DÉPARTEMENT D'INFORMATIQUE
SÉCURITÉ IT

MODULE « SÉCURITÉ DES RÉSEAUX ET SYSTÈMES »

Conception et sécurisation d'une
architecture Entreprise avec OpenVPN,
pfSense et Suricata

Élève Ingénieur :
MAMAN ABOUBAKAR Moïse

Enseignant :
Pr. Charafeddine
AITZAOUAT

10 juin 2026

Table des matières

1	Contexte et Architecture	3
1.1	Contexte	3
1.2	Objectif	3
1.3	Machines Virtuelles	3
1.4	Réseaux VirtualBox	3
1.4.1	pfSense	3
1.4.2	Ubuntu Server	4
1.4.3	Windows Client	4
1.4.4	Kali Linux	4
1.5	Plan d'adressage	4
1.5.1	Réseau LAN interne	4
1.5.2	Réseau VPN	4
2	Mise en place architecture	5
2.1	Kali linux	6
2.2	Ubuntu_Server	6
2.3	Pfsense	7
2.4	OST2 (Windows Client)	8
2.5	Test de connectivité	8
3	Déploiement OpenVPN	9
4	Durcissement du serveur Ubuntu	18
4.1	Durcissement système	18
4.1.1	Mise à jour Système	18
4.1.2	Suppression des services inutiles	20
4.1.3	Désactivation de l'IPv6 et configuration de sysctl	21
4.1.4	Activation du firewall ufw	22
4.1.5	Sécurisation GRUB	24
4.1.6	Limitation accès root	25
4.2	Sécurisation PAM	26
4.2.1	Expiration mot de passe	26
4.2.2	Complexité PAM	27
4.2.3	Verrouillage tentative	28
4.3	Securisation SSH	29
4.3.1	Génération des clés	29
4.3.2	Configuration générale de sshd_config	30
5	Services sur Ubuntu Server	32
6	Déploiement IDS/IPS	33
6.1	Installation Suricata	33
6.2	Configuration des paramètres globaux	34
6.3	Activation IDS	36
6.4	Activation IPS inline mode	36
6.5	Configuration Détection	37



7	Attaques Kali Linux	38
8	Firewalling	40
9	Références	42

1 Contexte et Architecture

1.1 Contexte

Une entreprise souhaite déployer une architecture sécurisée permettant :

- l'accès distant sécurisé des employés
- la protection d'un serveur Linux critique
- la détection des attaques externes
- la supervision des événements de sécurité

1.2 Objectif

- concevoir une architecture sécurisée
- mettre en place un VPN Client-to-Site
- durcir un serveur Linux
- sécuriser SSH et les accès
- configurer un IDS/IPS
- détecter et bloquer des attaques
- analyser des logs sécurité

1.3 Machines Virtuelles

Machine	OS	Rôle
pfsense	pfSense CE	Firewall+OpenVPN+IDS/IPS
Ubuntu Server	Ubuntu server	Serveur interne sécurisé
Windows Client	Windows 10	Client OpenVPN distant
Kali Linux	Kali linux	Machine attaquante

TABLE 1

1.4 Réseaux VirtualBox

1.4.1 pfsense

Interface	Mode
Wan	Bridged Adapter
Lan	Host-Only Adapter

TABLE 2

1.4.2 Ubuntu Server

Interface	Mode
NIC 1	Host-Only Adapter

TABLE 3

1.4.3 Windows Client

Interface	Mode
NIC 1	Bridged Adapter

TABLE 4

1.4.4 Kali Linux

Interface	Mode
NIC 1	Bridged Adapter

TABLE 5

1.5 Plan d'adressage

1.5.1 Réseau LAN interne

Machine	IP
pfsense Lan	192.168.10.1/24
Ubuntu Server	192.168.10.10/24

TABLE 6

1.5.2 Réseau VPN

Réseau VPN	10.8.0.0/24
------------	-------------

TABLE 7

2 Mise en place architecture

Pour répondre aux exigences de l'architecture, nous avons installé nos machines virtuelles comme suit, accompagnées d'une machine en plus correspondant au laptop de l'administrateur lorsqu'il est en dehors de l'entreprise pour lui permettre d'effectuer des tâches même à distance :

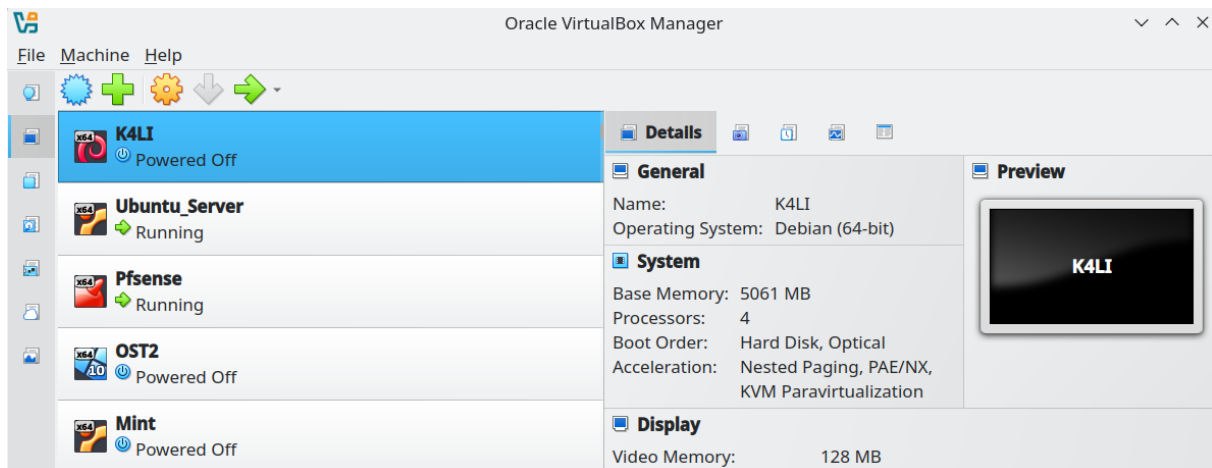


FIGURE 1

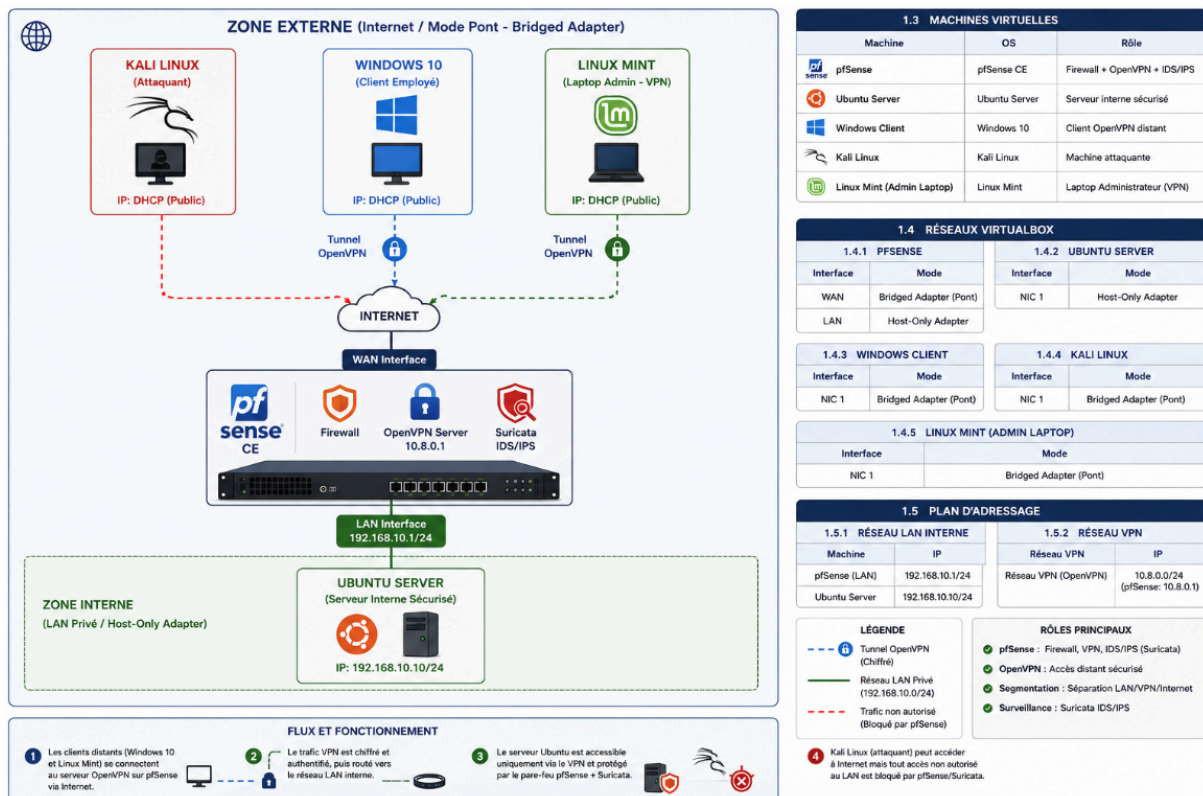
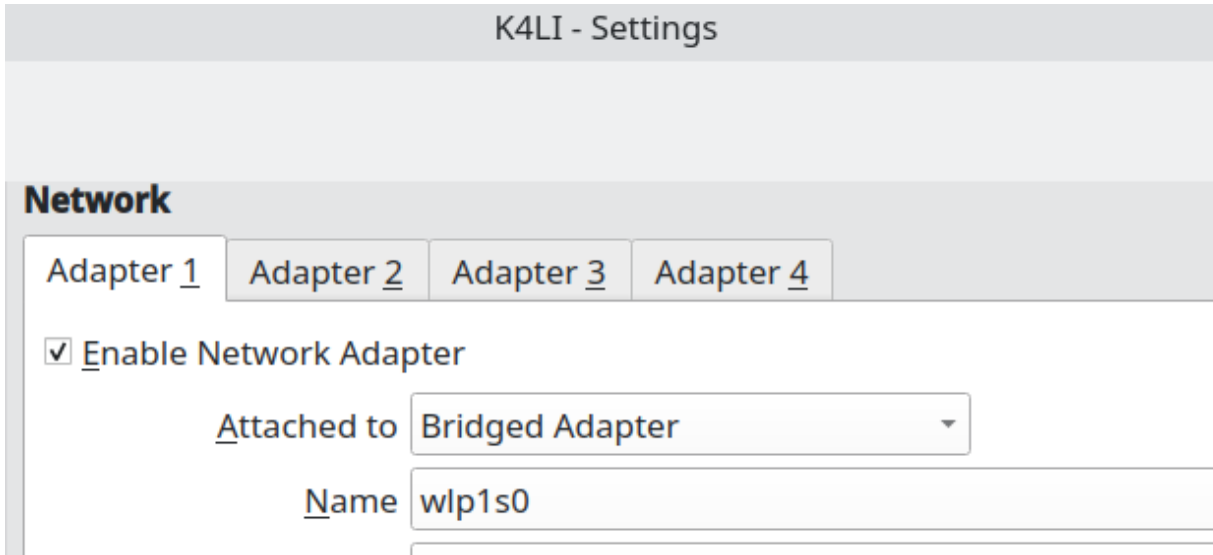


FIGURE 2

2.1 Kali linux

Nous avons configuré le premier adaptateur de notre machine Kali en mode **Bridged adapter** comme suit :

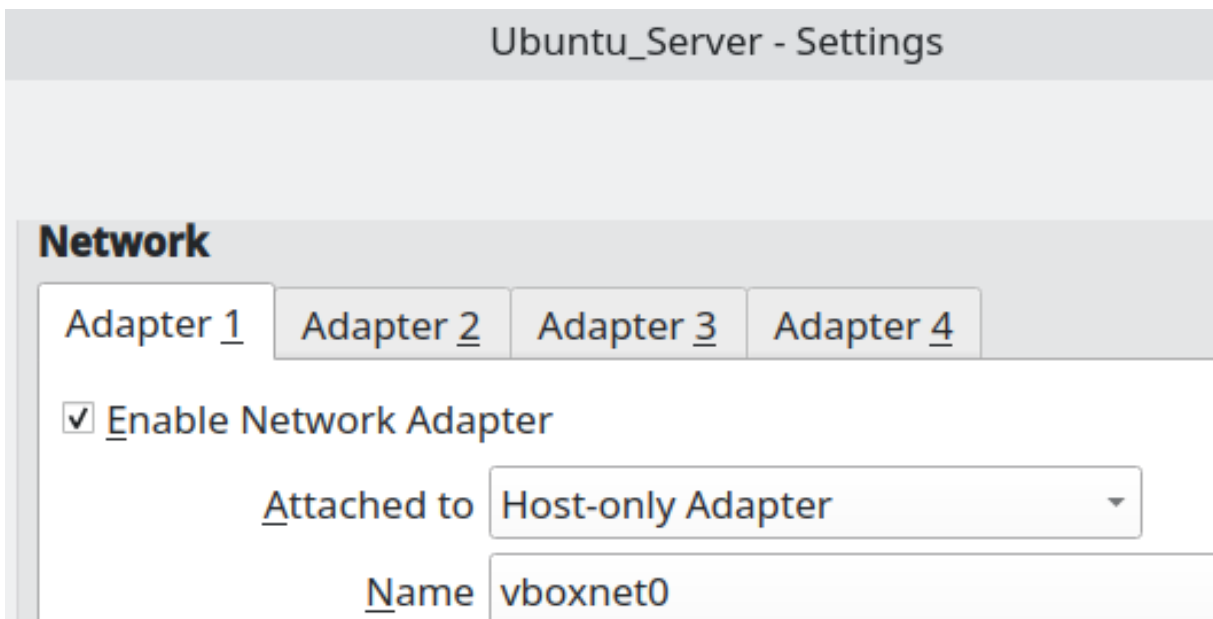


The screenshot shows the 'K4LI - Settings' window with the 'Network' tab selected. Under the 'Network' section, there are four tabs: 'Adapter 1', 'Adapter 2', 'Adapter 3', and 'Adapter 4'. The 'Adapter 1' tab is active. Below the tabs, there is a checkbox labeled 'Enable Network Adapter' which is checked. Below this, there is a dropdown menu labeled 'Attached to' with 'Bridged Adapter' selected. Below the dropdown, there is a text input field labeled 'Name' with 'wlp1s0' entered.

FIGURE 3

2.2 Ubuntu_Server

Nous avons configuré le premier adaptateur de notre serveur Ubuntu en mode **Host-Only adapter** comme suit :



The screenshot shows the 'Ubuntu_Server - Settings' window with the 'Network' tab selected. Under the 'Network' section, there are four tabs: 'Adapter 1', 'Adapter 2', 'Adapter 3', and 'Adapter 4'. The 'Adapter 1' tab is active. Below the tabs, there is a checkbox labeled 'Enable Network Adapter' which is checked. Below this, there is a dropdown menu labeled 'Attached to' with 'Host-only Adapter' selected. Below the dropdown, there is a text input field labeled 'Name' with 'vboxnet0' entered.

FIGURE 4

Nous avons par la suite modifié le fichier de configuration de l'interface pour lui assigner une adresse IP statique correspondant au plan d'adressage ainsi que la passerelle.

```
GNU nano 7.2 /etc/netplan/00-installer-config.yaml *
# This is the network config written by 'subiquity'
network:
  ethernets:
    enp0s3:
      dhcp4: false
      addresses:
        - 192.168.10.10/24
      routes:
        - to: default
          via: 192.168.10.1
      nameservers:
        addresses: [1.1.1.1, 1.0.0.1]
  version: 2
```

FIGURE 5

2.3 PfSense

Nous avons configuré les deux premiers adaptateurs de notre firewall pfSense en mode **Bridged** et **Host-Only adapter** comme suit :

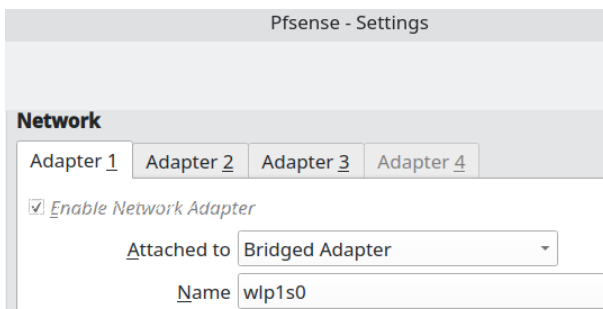


FIGURE 6

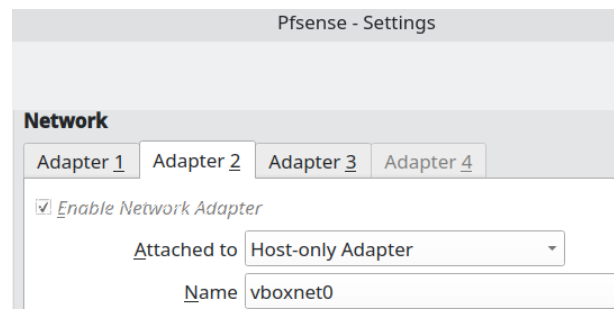


FIGURE 7

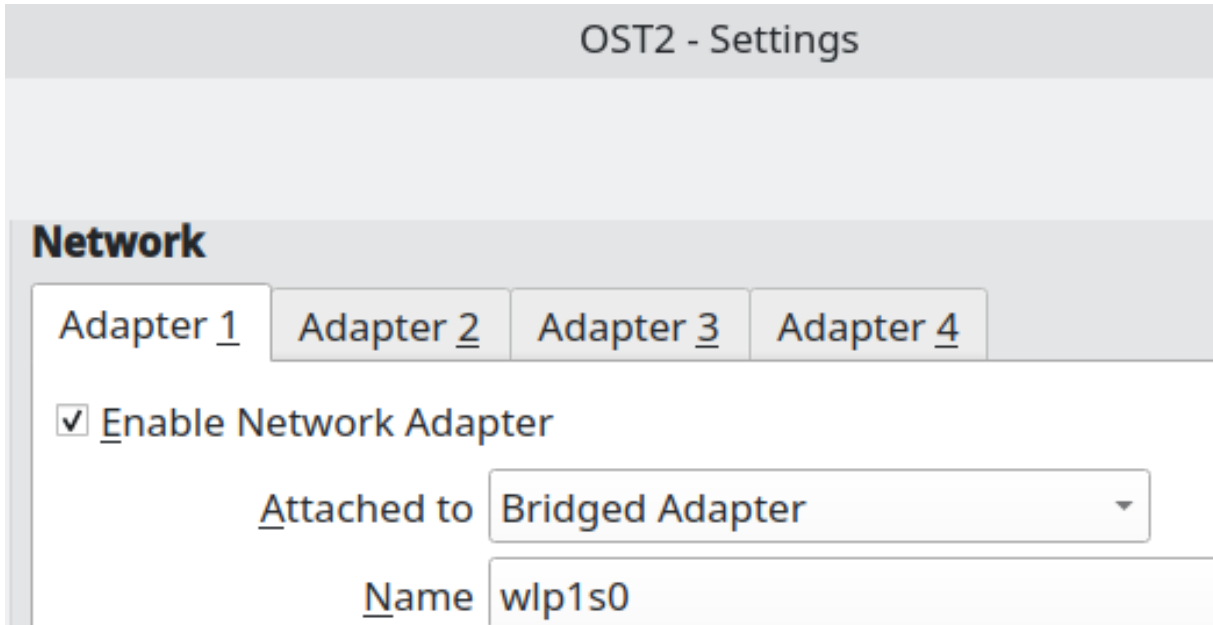
Nous avons configuré l'interface LAN pour lui assigner une IP statique qui correspond au plan d'adressage.

```
Pfsense [Running] - Oracle VirtualBox
File Machine View Input Devices Help
The IPv4 LAN address has been set to 192.168.10.1/24
You can now access the webConfigurator by opening the following URL in your web
browser:
    http://192.168.10.1/
Press <ENTER> to continue.
VirtualBox Virtual Machine - Netgate Device ID: ebfe9eda802585a6c050
*** Welcome to pfSense 2.8.1-RELEASE (amd64) on pfSense ***
WAN (wan) -> em0 -> v4/DHCP4: 192.168.11.111/24
LAN (lan) -> em1 -> v4: 192.168.10.1/24
```

FIGURE 8

2.4 OST2 (Windows Client)

Nous avons également configuré le premier adaptateur de notre client Windows en mode **Bridged adapter** comme suit :



OST2 - Settings

Network

Adapter 1 Adapter 2 Adapter 3 Adapter 4

☒ Enable Network Adapter

Attached to Bridged Adapter

Name wlp1s0

FIGURE 9

2.5 Test de connectivité

Nous avons lancé 4 paquets ICMP Echo Request à partir du serveur Ubuntu vers notre interface LAN pfSense pour tester la connectivité au sein de notre LAN.

```
shinra@souleater:~$ ping -c 4 192.168.10.1
PING 192.168.10.1 (192.168.10.1) 56(84) bytes of data.
64 bytes from 192.168.10.1: icmp_seq=1 ttl=64 time=1.74 ms
64 bytes from 192.168.10.1: icmp_seq=2 ttl=64 time=0.634 ms
64 bytes from 192.168.10.1: icmp_seq=3 ttl=64 time=0.487 ms
64 bytes from 192.168.10.1: icmp_seq=4 ttl=64 time=0.694 ms

--- 192.168.10.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3089ms
rtt min/avg/max/mdev = 0.487/0.887/1.736/0.495 ms
shinra@souleater:~$
```

FIGURE 10

3 Déploiement OpenVPN

Nous avons accédé à l'interface Web de notre pfSense puis par la suite à la section pour créer les certificats.

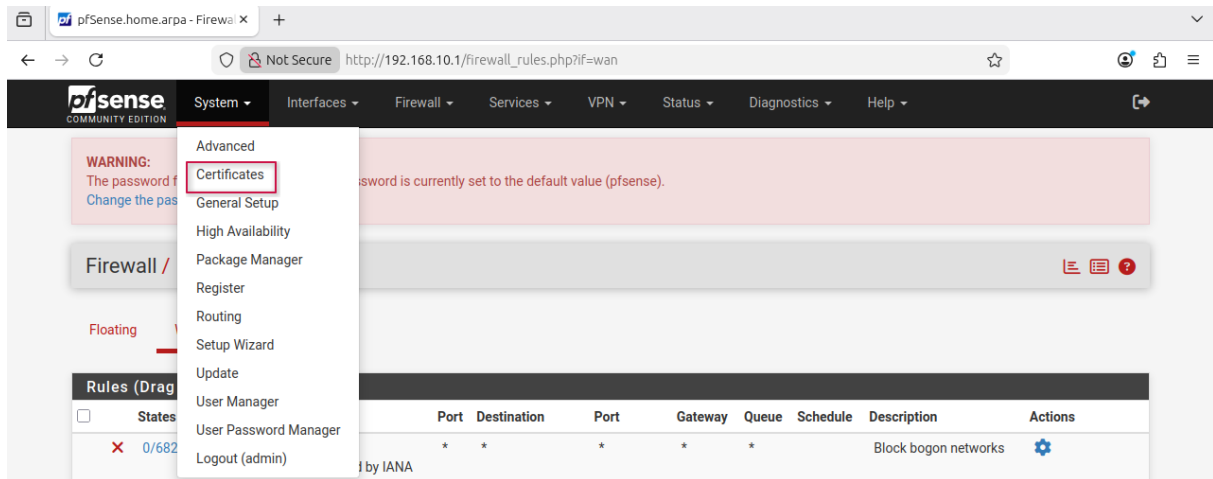


FIGURE 11

Nous avons mis le nom ainsi que le common name concernant le certificat de l'autorité que nous avons créée.

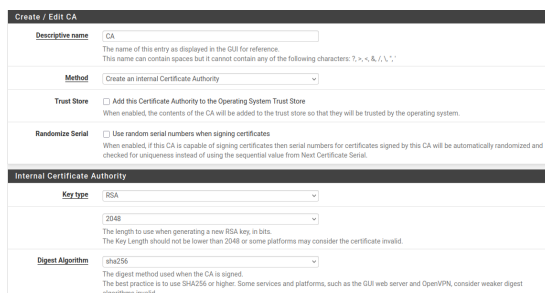


FIGURE 12

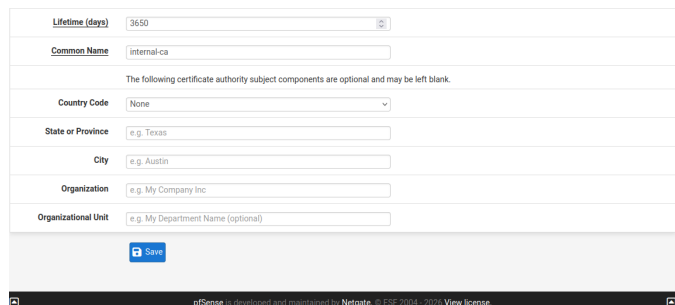


FIGURE 13

Par la suite, nous avons configuré le certificat qui sera utilisé par notre serveur OpenVPN en spécifiant un nom ainsi qu'en mettant le type de certificat pour celui d'un serveur.

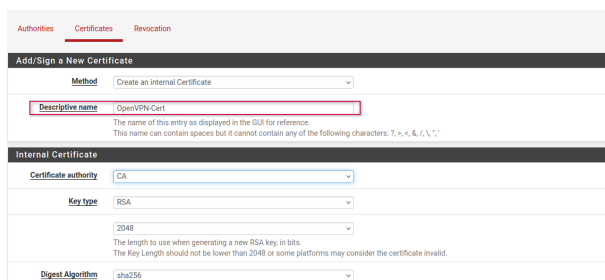


FIGURE 14

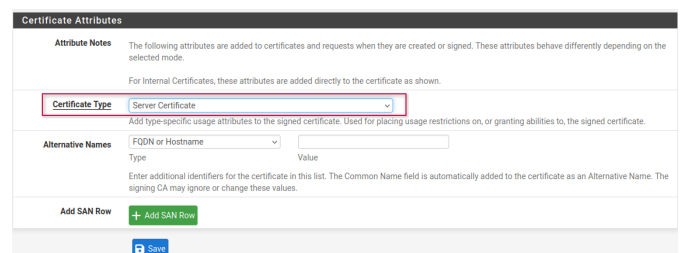


FIGURE 15

Nous avons par la suite accédé à la section VPN pour configurer notre OpenVPN.

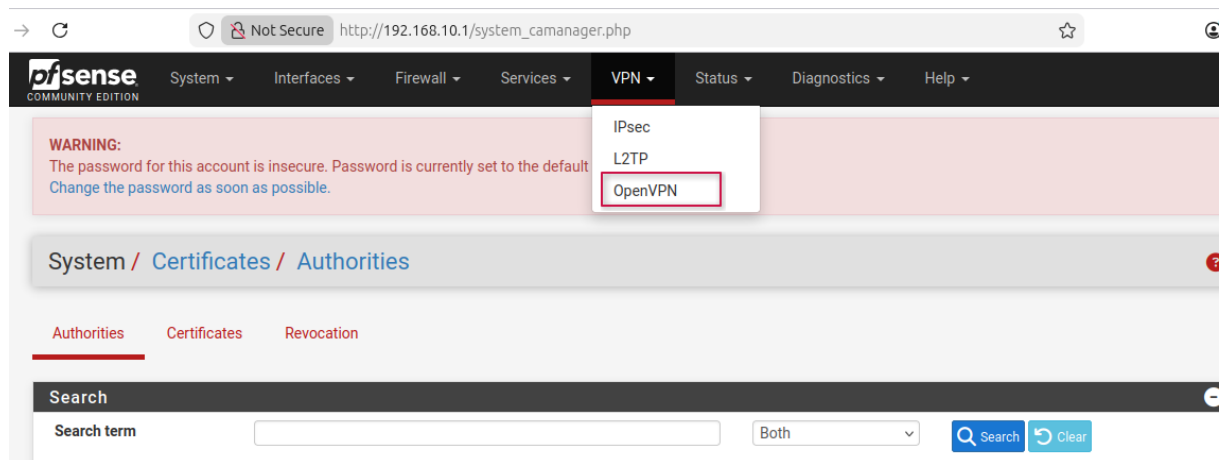


FIGURE 16

Nous allons nous servir du wizard pour configurer notre serveur OpenVPN. Nous allons choisir comme autorité de certification celle que nous avons créée précédemment.

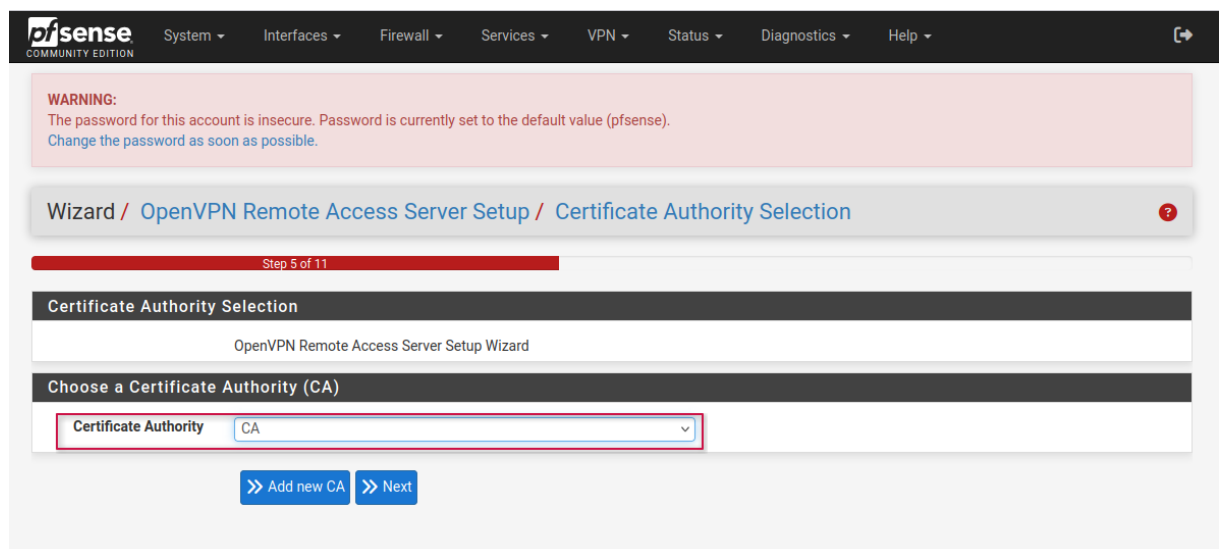


FIGURE 17

Par la suite, nous allons aussi sélectionner le certificat qui va être utilisé par notre serveur OpenVPN.

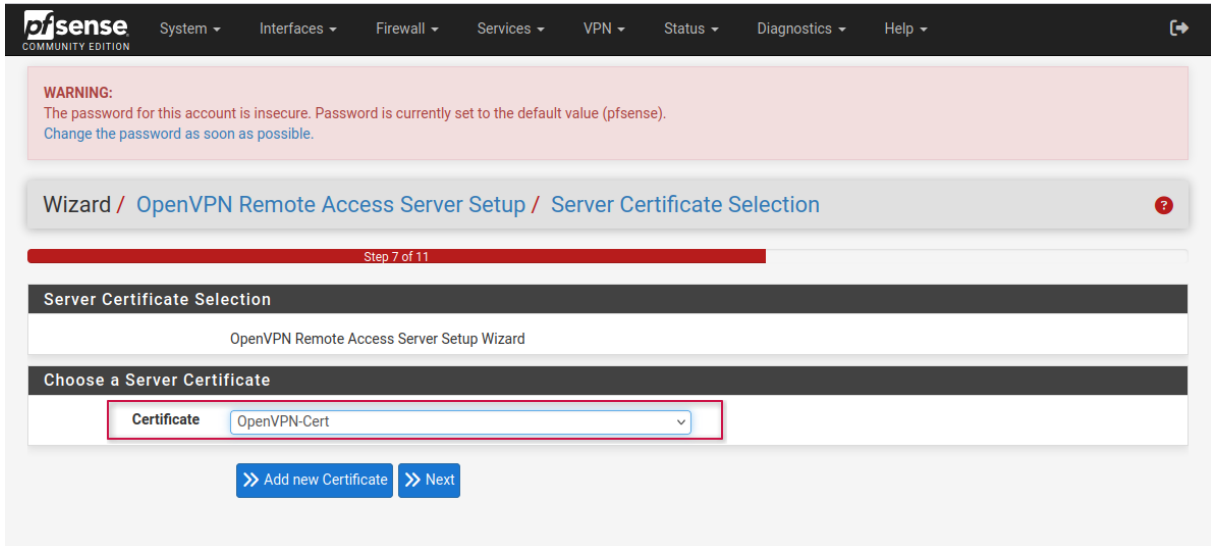


FIGURE 18

La prochaine étape consistait à définir le port à utiliser ainsi que le protocole de la couche transport à utiliser qui est UDP.

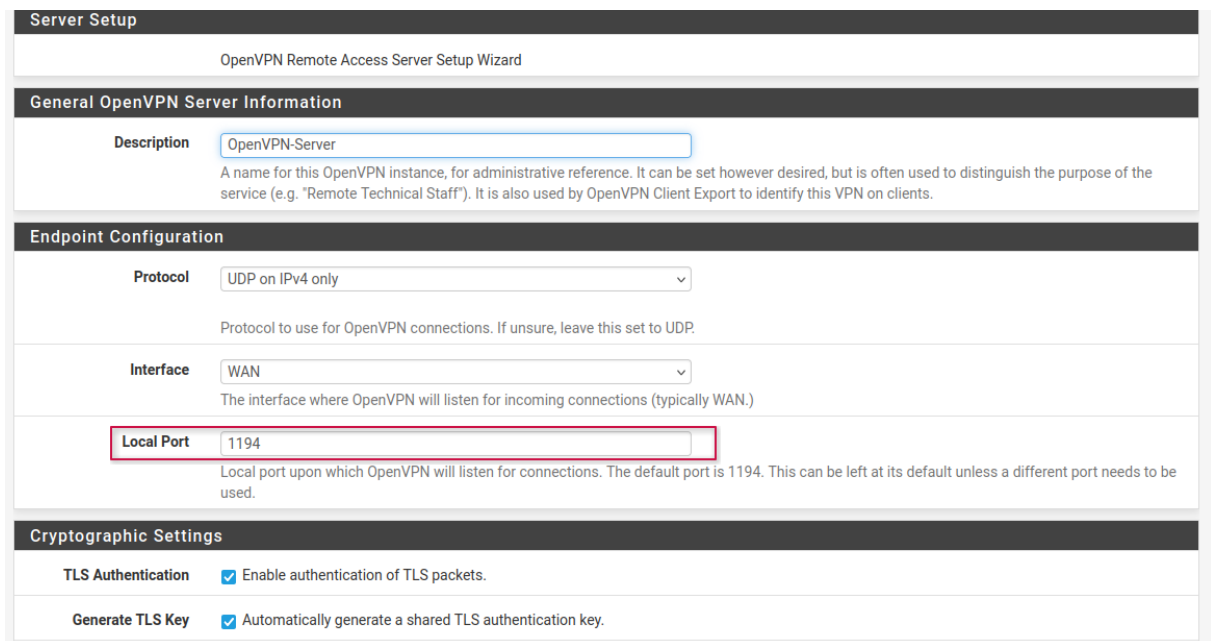
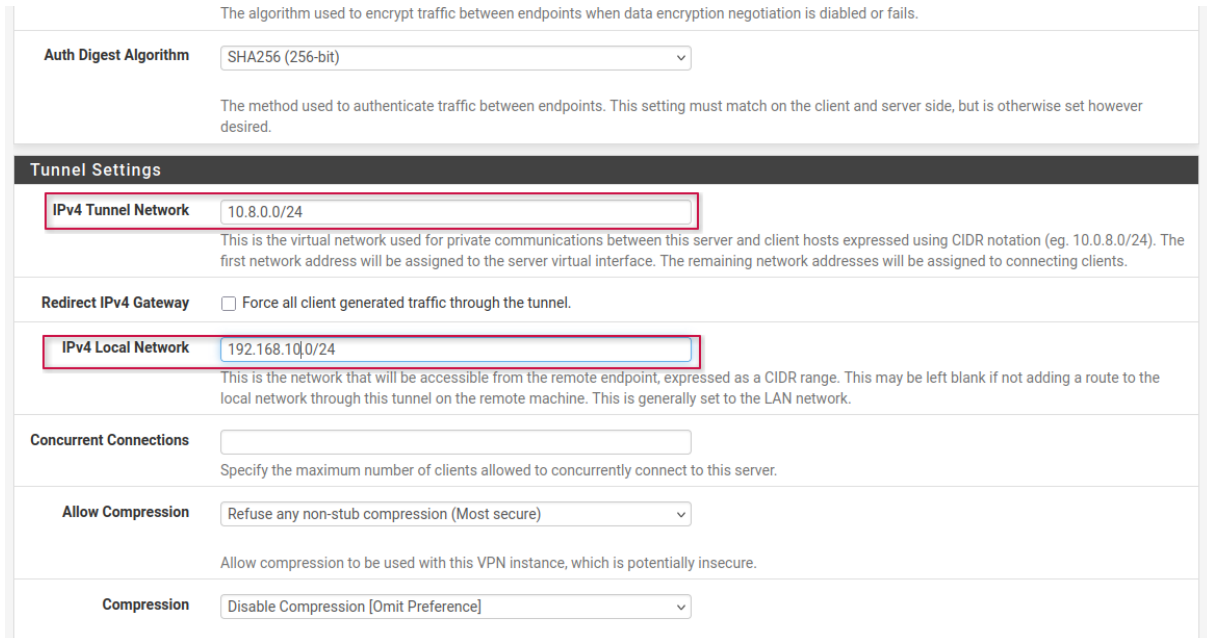


FIGURE 19

Concernant la partie de configuration du tunnel, nous avons dû saisir le réseau formé par le tunnel et par la suite le réseau LAN auquel nos clients VPN pourront accéder.



The algorithm used to encrypt traffic between endpoints when data encryption negotiation is disabled or fails.

Auth Digest Algorithm: SHA256 (256-bit)

The method used to authenticate traffic between endpoints. This setting must match on the client and server side, but is otherwise set however desired.

Tunnel Settings

IPv4 Tunnel Network: 10.8.0.0/24

This is the virtual network used for private communications between this server and client hosts expressed using CIDR notation (eg. 10.0.8.0/24). The first network address will be assigned to the server virtual interface. The remaining network addresses will be assigned to connecting clients.

Redirect IPv4 Gateway: ☐ Force all client generated traffic through the tunnel.

IPv4 Local Network: 192.168.10.0/24

This is the network that will be accessible from the remote endpoint, expressed as a CIDR range. This may be left blank if not adding a route to the local network through this tunnel on the remote machine. This is generally set to the LAN network.

Concurrent Connections:

Specify the maximum number of clients allowed to concurrently connect to this server.

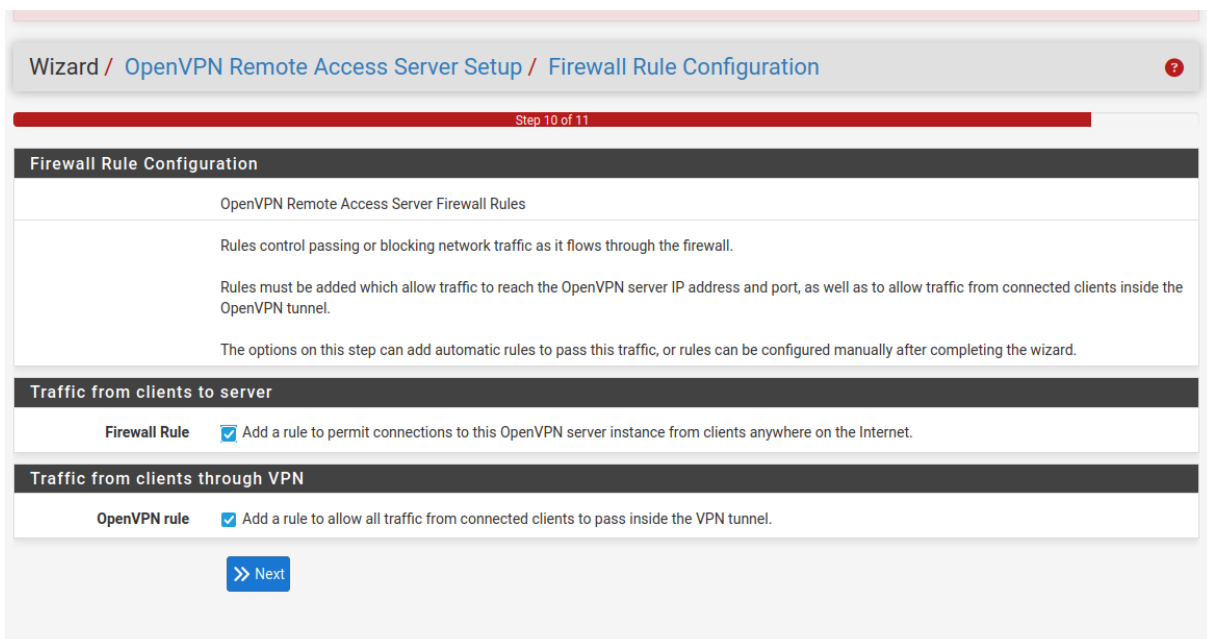
Allow Compression: Refuse any non-stub compression (Most secure)

Allow compression to be used with this VPN instance, which is potentially insecure.

Compression: Disable Compression [Omit Preference]

FIGURE 20

Pour finir, il faudra cocher les deux options pour permettre la connexion au serveur OpenVPN par n'importe quel client sur Internet et aussi permettre au trafic du LAN de passer par le tunnel.



Wizard / OpenVPN Remote Access Server Setup / Firewall Rule Configuration

Step 10 of 11

Firewall Rule Configuration

OpenVPN Remote Access Server Firewall Rules

Rules control passing or blocking network traffic as it flows through the firewall.

Rules must be added which allow traffic to reach the OpenVPN server IP address and port, as well as to allow traffic from connected clients inside the OpenVPN tunnel.

The options on this step can add automatic rules to pass this traffic, or rules can be configured manually after completing the wizard.

Traffic from clients to server

Firewall Rule: ☒ Add a rule to permit connections to this OpenVPN server instance from clients anywhere on the Internet.

Traffic from clients through VPN

OpenVPN rule: ☒ Add a rule to allow all traffic from connected clients to pass inside the VPN tunnel.

>> Next

FIGURE 21

Après avoir fini de configurer notre serveur OpenVPN, nous avons créé un utilisateur local au niveau de notre firewall en spécifiant un nom d'utilisateur, un mot de passe ainsi qu'un nom pour des utilisations administratives.

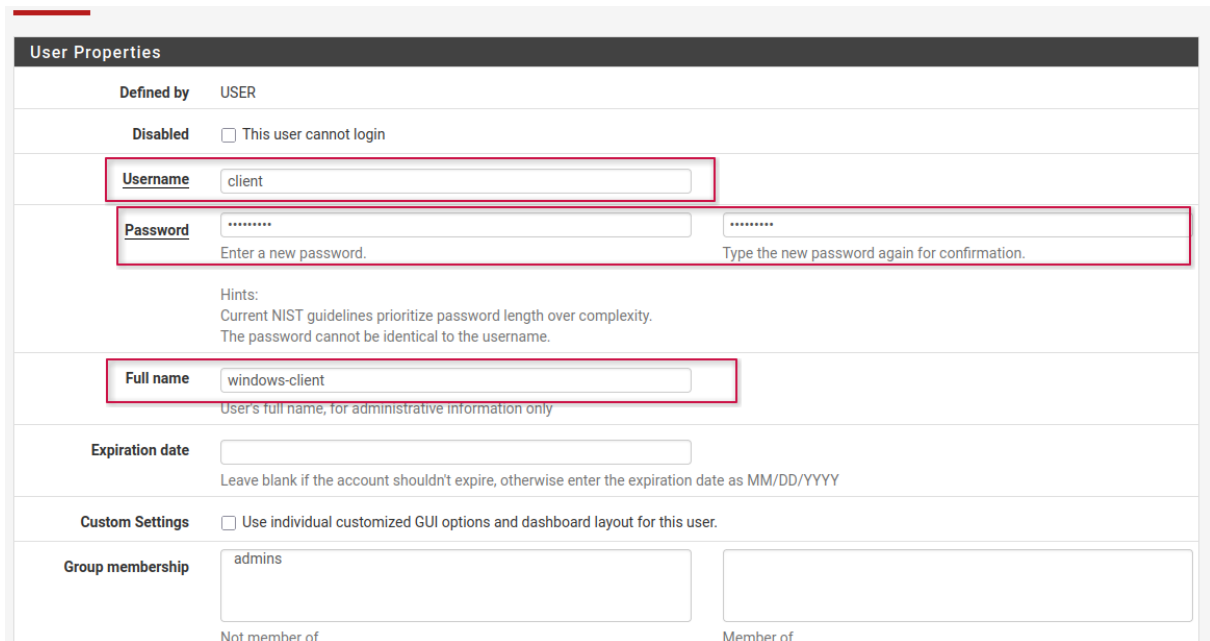


FIGURE 22

Par la suite, nous avons créé aussi un certificat pour cet utilisateur qui a été authentifié par la CA.

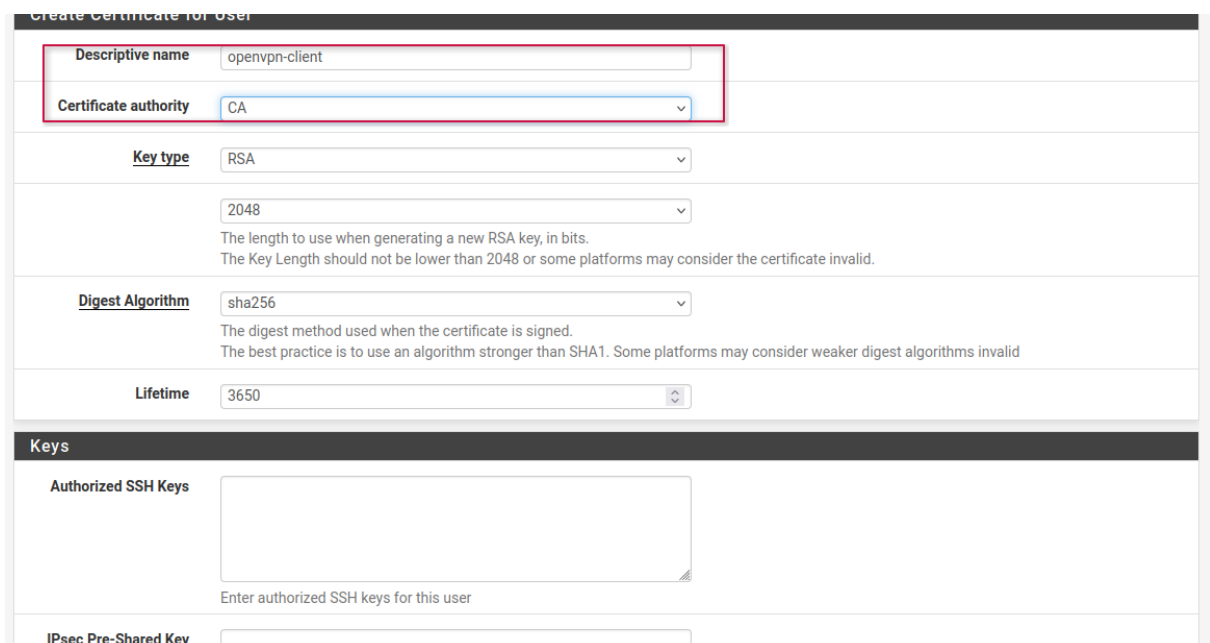


FIGURE 23

Nous avons exporté notre client local OpenVPN sur Windows en changeant l'adaptateur de notre machine en Host-Only pour pouvoir accéder à la page Web de notre pfSense, pouvoir le télécharger et finalement l'installer sur Windows.

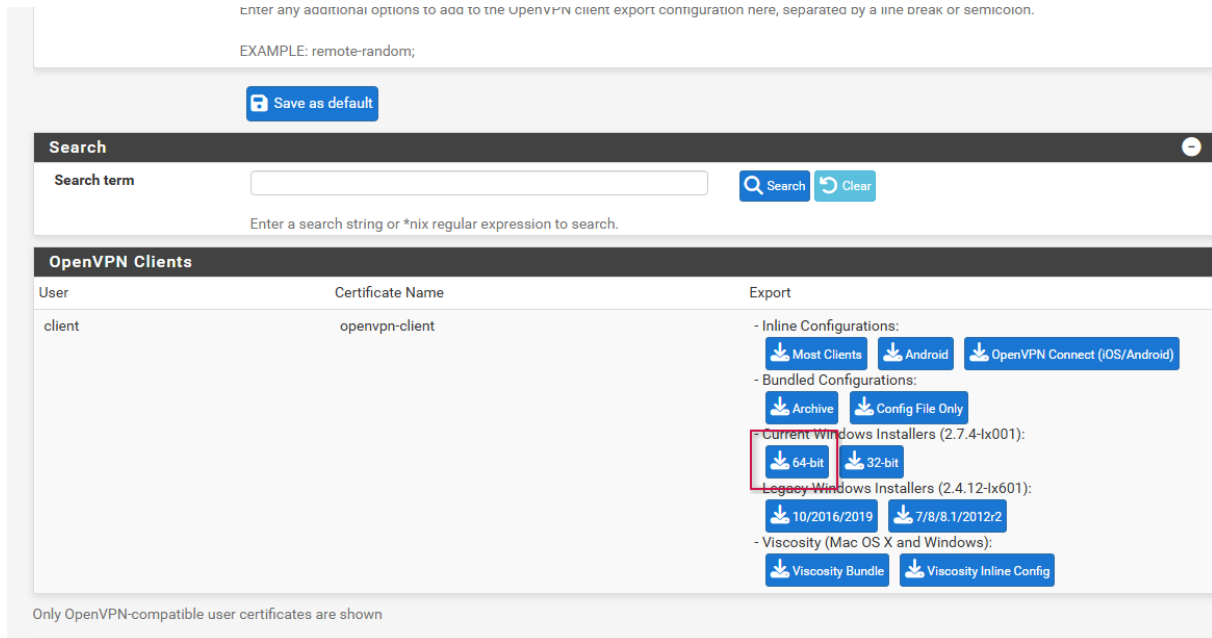


FIGURE 24

Une fois téléchargé, nous avons installé notre client VPN sur notre machine Windows comme présenté ci-dessous.

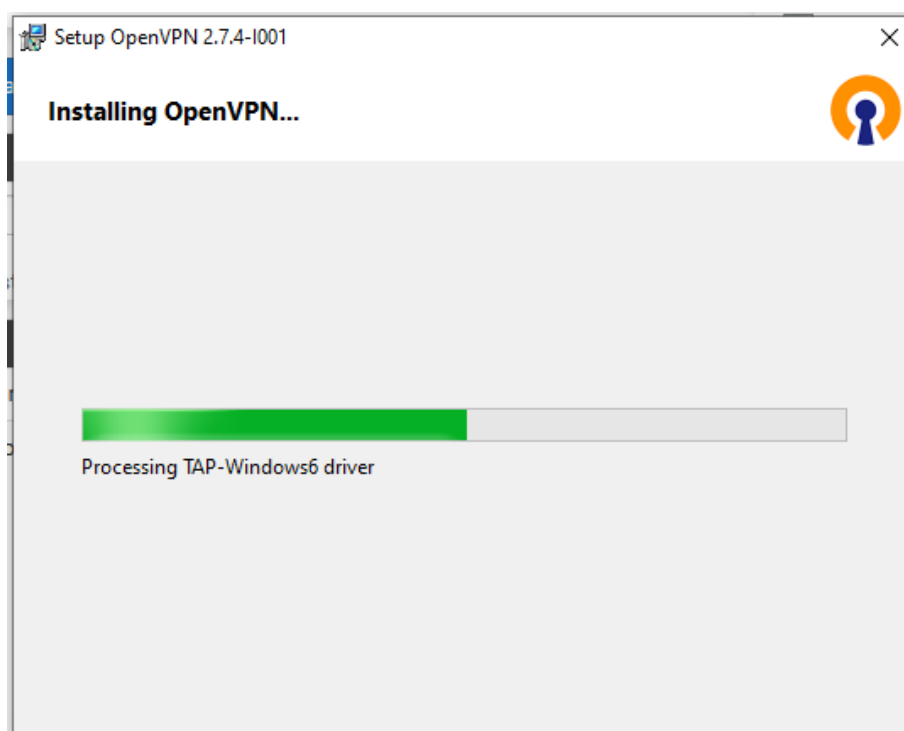


FIGURE 25

Pour pouvoir se connecter à notre VPN, nous avons appuyé sur l'icône en forme d'ordinateur avec un cadenas au niveau de notre zone de notification, puis appuyé sur **Connecter**. Cela fait apparaître l'interface ci-contre dans laquelle nous devons insérer le nom d'utilisateur et le mot de passe qu'on a eu à définir pour l'utilisateur local de notre pfSense.

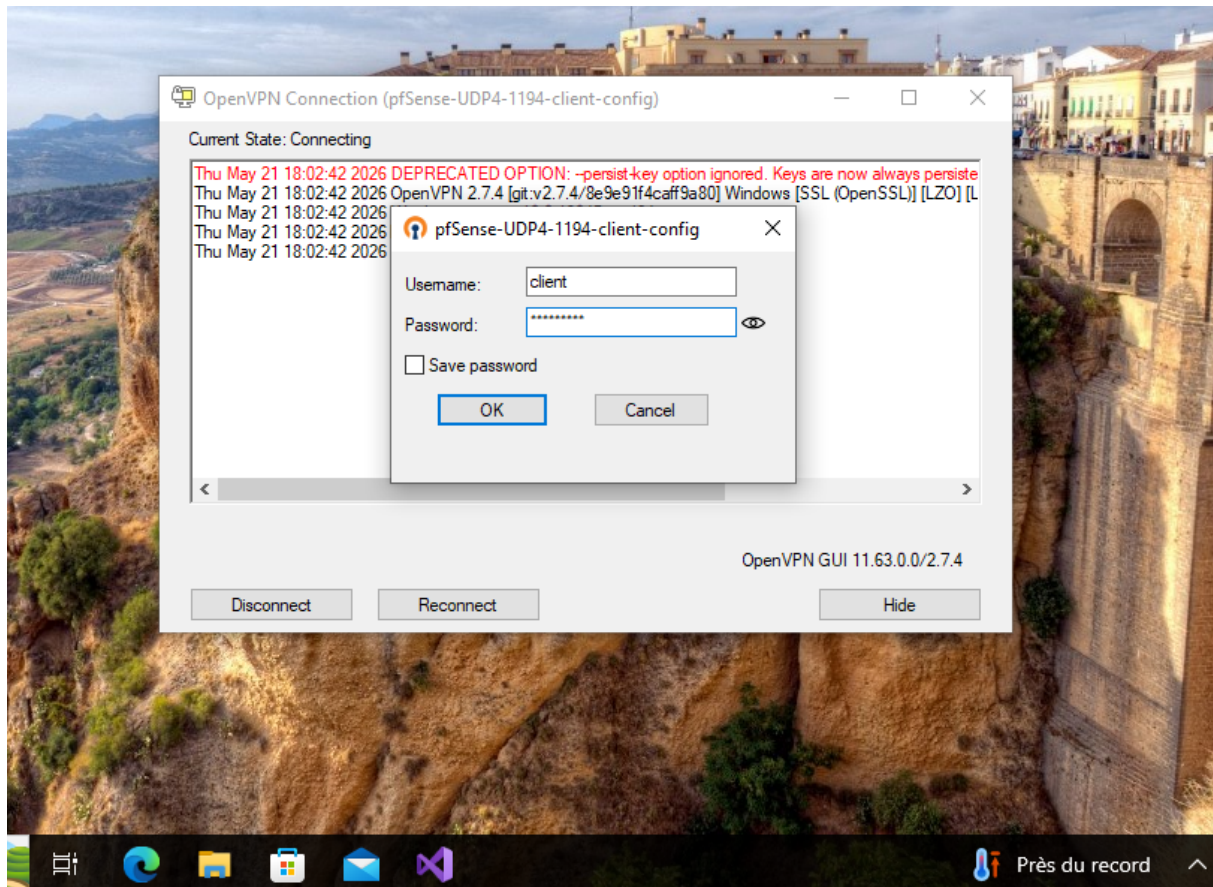


FIGURE 26

Une fois les identifiants corrects entrés, la connexion est établie, ce qui peut être vérifié par la création de l'interface virtuelle pour le tunnel quand on tape **ipconfig /all** au niveau de l'invite de commandes comme affiché ci-dessous. De plus, une notification apparaît au niveau de la fenêtre des notifications, signalant aussi que la connexion a été établie.

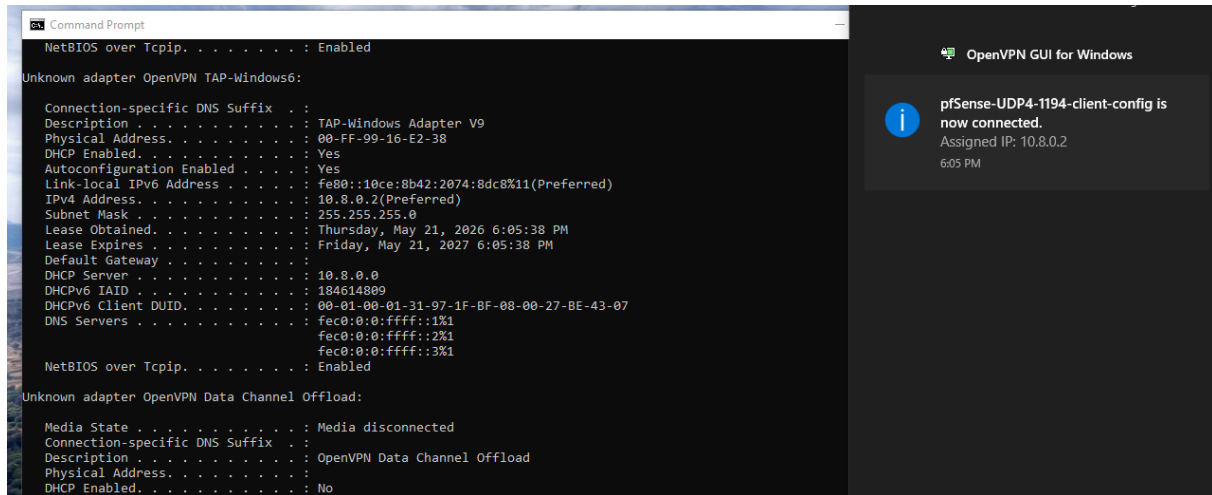


FIGURE 27

Mais pour être sûrs, nous avons initié d'autres méthodes de vérification en plus de cela. Pour cela, nous avons commencé par envoyer un ping à notre serveur Ubuntu via son adresse IP locale ; ce dernier répond et cela fonctionne comme présenté ci-dessous.

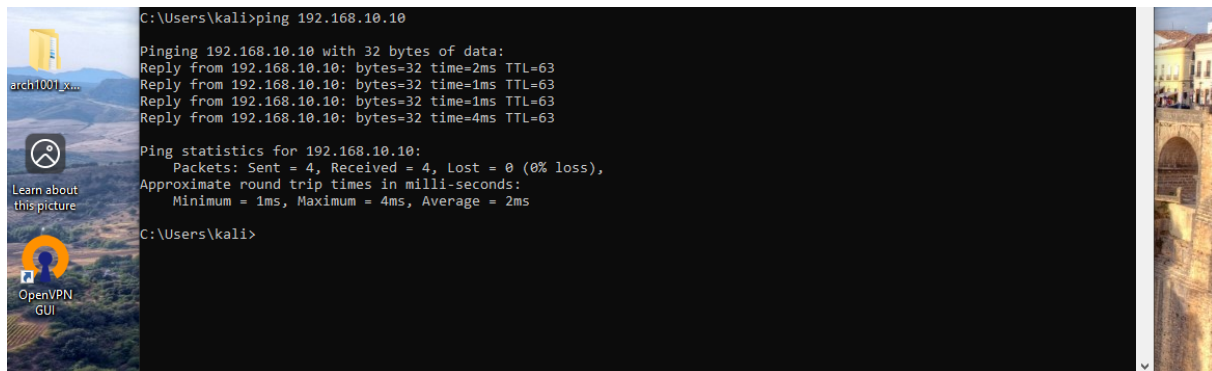


FIGURE 28

En deuxième lieu, nous avons tenté d'accéder à la page Web présente sur notre serveur Ubuntu via HTTP, nous assurant ainsi que notre service Apache2 est opérationnel.

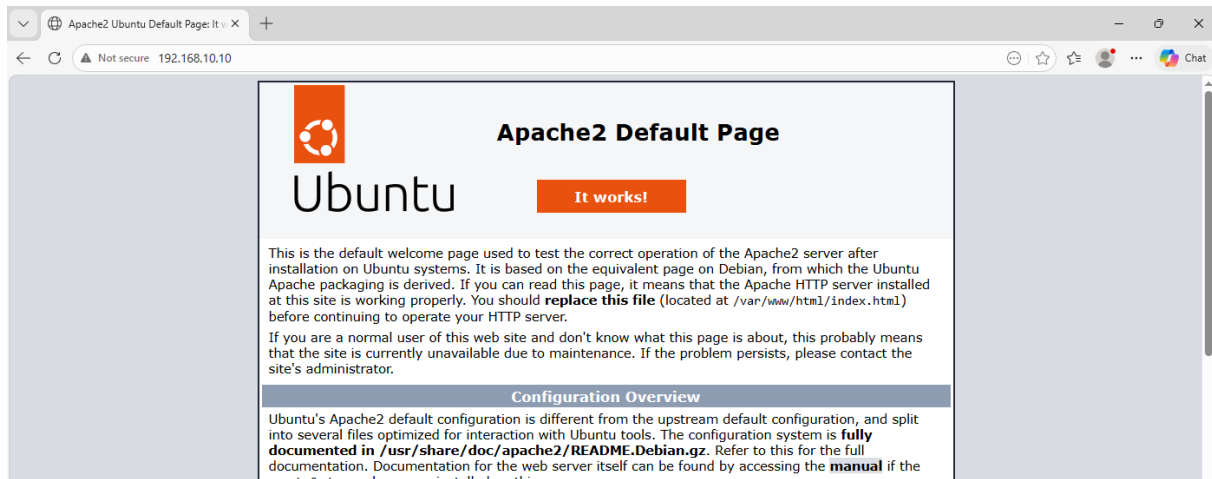


FIGURE 29

Troisièmement, nous avons tenté d'accéder à notre serveur Ubuntu via SSH à partir de notre machine Windows.

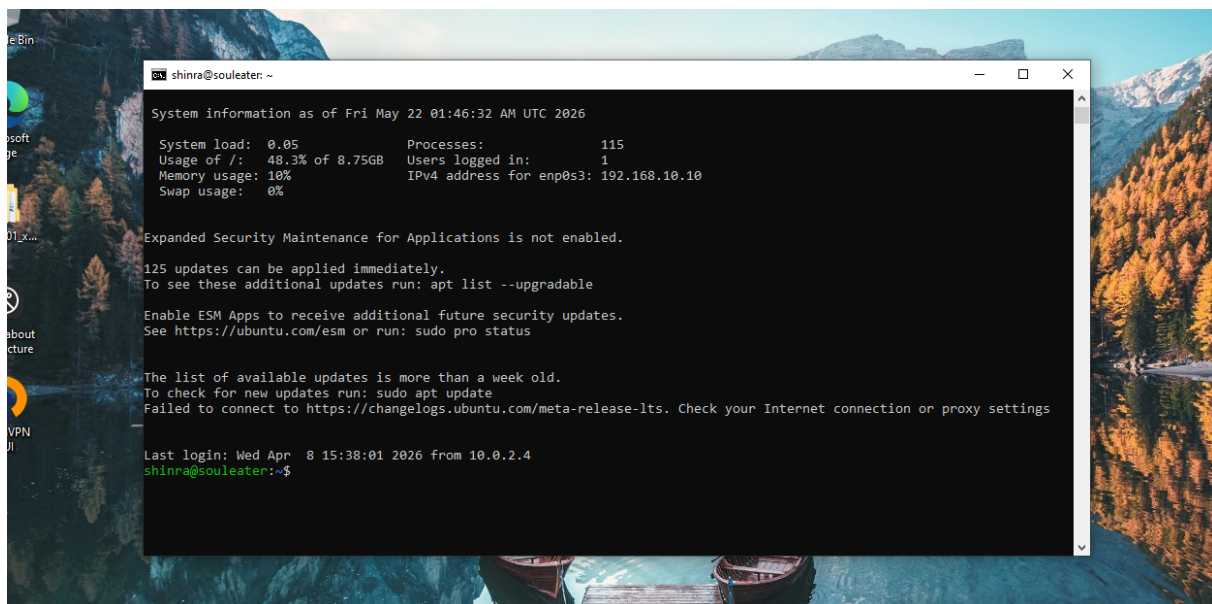


FIGURE 30

4 Durcissement du serveur Ubuntu

4.1 Durcissement système

4.1.1 Mise à jour Système

Pour assurer le durcissement de notre système, nous devons passer par plusieurs étapes. En premier lieu, nous devons mettre à jour notre système. Pour cela, nous avons tout d'abord mis à jour notre liste de mises à jour disponibles pour les paquets installés via **sudo apt update**, et par la suite la commande **sudo apt dist-upgrade** va installer et télécharger ces mises à jour tout en prenant en compte de manière intelligente les dépendances et potentiellement supprimer les paquets indésirables, contrairement à **apt upgrade**.

```
Get:35 http://ma.archive.ubuntu.com/ubuntu noble-backports/main amd64 Packages [40.6 kB]
Get:36 http://ma.archive.ubuntu.com/ubuntu noble-backports/main Translation-en [9,172 B]
Get:37 http://ma.archive.ubuntu.com/ubuntu noble-backports/main amd64 Components [5,744 B]
Get:38 http://ma.archive.ubuntu.com/ubuntu noble-backports/main amd64 c-n-f Metadata [368 B]
Get:39 http://ma.archive.ubuntu.com/ubuntu noble-backports/restricted amd64 Components [212 B]
Get:40 http://ma.archive.ubuntu.com/ubuntu noble-backports/universe amd64 Packages [31.0 kB]
Get:41 http://ma.archive.ubuntu.com/ubuntu noble-backports/universe Translation-en [18.6 kB]
Get:42 http://ma.archive.ubuntu.com/ubuntu noble-backports/universe amd64 Components [10.6 kB]
Get:43 http://ma.archive.ubuntu.com/ubuntu noble-backports/universe amd64 c-n-f Metadata [1,484 B]
Get:44 http://ma.archive.ubuntu.com/ubuntu noble-backports/multiverse amd64 Packages [748 B]
Get:45 http://ma.archive.ubuntu.com/ubuntu noble-backports/multiverse amd64 Components [212 B]
Fetched 16.8 MB in 13s (1,310 kB/s)
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
181 packages can be upgraded. Run 'apt list --upgradable' to see them.
shinra@souleater:~$
```

FIGURE 31

```
shinra@souleater:~$ sudo apt dist-upgrade
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Calculating upgrade... Done
The following NEW packages will be installed:
  linux-headers-6.8.0-117 linux-headers-6.8.0-117-generic linux-image-6.8.0-117-generic linux-module
  linux-tools-6.8.0-117 linux-tools-6.8.0-117-generic python3-boto3 python3-botoecore python3-dateutil
The following packages will be upgraded:
  apache2 apache2-bin apache2-data apache2-utils apparmor apt apt-utils base-files bind9-dnsutils bi
  cloud-initramfs-dyn-netconf coreutils cryptsetup cryptsetup-bin cryptsetup-initramfs curl dhcpd-b
  dracut-install fwupd gir1.2-packagekit-glib-1.0 gzip ibverbs-providers initramfs-tools initramfs-to
  landscape-common libacl1 libaio1t64 libapparmor1 libapt-pkg6.0t64 libarchive13t64 libattr1 libaudi
  libcryptsetup12 libcurl3t64-gnutls libcurl4t64 libdevmapper-event1.02.1 libdevmapper1.02.1 libdrm-
  libgpg-error-l10n libgpg-error0 libheif-plugin-aomdec libheif-plugin-aomenc libheif-plugin-libde26
  libldap-common libldap2 liblvm2cmd2.03 libmbim-glib4 libmbim-proxy libmbim-utils libmd0 libmpfr6 l
  libnl-genl-3-200 libnl-route-3-200 libnss-systemd libntfs-3g89t64 libnuma1 libnvme1t64 libopeniscs
  libpcre2-8-0 libplymouth5 libpng16-16t64 libpolkit-agent-1-0 libpolkit-gobject-1-0 libproc2-0 libp
  libselinux1 libssl3t64 libsystemd-shared libsystemd0 libtraceevent1 libtraceevent1-plugin libudev1
  linux-generic linux-headers-generic linux-image-generic linux-libc-dev linux-tools-common login ls
  multipath-tools netplan-generator netplan.io nftables ntfs-3g numactl open-iscsi open-vm-tools ope
  overlayroot packagekit packagekit-tools passwd pci.ids plymouth plymouth-theme-ubuntu-text polkitd
  python3-distupgrade python3-netplan python3-software-properties python3-update-manager python3.12
  software-properties-common sosreport systemd systemd-dev systemd-hwe-hwdb systemd-resolved systemd
  ubuntu-drivers-common ubuntu-pro-client ubuntu-pro-client-l10n ubuntu-release-upgrader-core udev u
  vim-runtime vim-tiny xfsprogs xxd
181 upgraded, 13 newly installed, 0 to remove and 0 not upgraded.
53 standard LTS security updates
Need to get 943 MB of archives.
After this operation, 481 MB of additional disk space will be used.
Do you want to continue? [Y/n]
```

FIGURE 32

4.1.2 Suppression des services inutiles

La prochaine étape consiste à identifier les services présents qui sont inutiles afin de pouvoir réduire les surfaces d'attaque. Pour cela, nous avons utilisé la commande **systemctl list-units --type=service --state=running** afin de pouvoir lister les services qui sont en cours d'exécution, identifier ceux qui sont inutiles et les empêcher de s'exécuter au démarrage, voire supprimer le paquet responsable du service. Cependant, comme présenté ci-dessous, notre système ne possède pas de service inutile en exécution.

```
shinra@souleater:~$ sudo systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
apache2.service                    loaded active running The Apache HTTP Server
cron.service                        loaded active running Regular background program processing daemon
dbus.service                       loaded active running D-Bus System Message Bus
fwupd.service                      loaded active running Firmware update daemon
getty@tty1.service                 loaded active running Getty on tty1
ModemManager.service               loaded active running Modem Manager
multipathd.service                 loaded active running Device-Mapper Multipath Device Controller
polkit.service                     loaded active running Authorization Manager
rsyslog.service                    loaded active running System Logging Service
systemd-journald.service            loaded active running Journal Service
systemd-logind.service              loaded active running User Login Management
systemd-networkd.service            loaded active running Network Configuration
systemd-resolved.service            loaded active running Network Name Resolution
systemd-timesyncd.service           loaded active running Network Time Synchronization
systemd-udevd.service               loaded active running Rule-based Manager for Device Events and Files
udisks2.service                    loaded active running Disk Manager
unattended-upgrades.service         loaded active running Unattended Upgrades Shutdown
upower.service                     loaded active running Daemon for power management
user@1000.service                  loaded active running User Manager for UID 1000
vsftpd.service                     loaded active running vsftpd FTP server

Legend: LOAD    → Reflects whether the unit definition was properly loaded.
          ACTIVE → The high-level unit activation state, i.e. generalization of SUB.
          SUB    → The low-level unit activation state, values depend on unit type.

20 loaded units listed.
```

FIGURE 33

4.1.3 Désactivation de l'IPv6 et configuration de sysctl

Par la suite, nous avons désactivé l'IPv6 tout en configurant sysctl, permettant de durcir le comportement réseau et de la mémoire du noyau Linux tout en respectant les recommandations CIS Benchmark.

Pour ce faire, nous avons inséré un ensemble de paramètres dans un fichier **99-hardening.conf** que nous avons créé dans le dossier **/etc/sysctl.d**.

```
#--- IP Forwarding
net.ipv4.ip_forward = 0
net.ipv6.conf.all.forwarding = 0

#--- Source Routing
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.conf.default.accept_source_route = 0
net.ipv6.conf.all.accept_source_route = 0
net.ipv6.conf.default.accept_source_route = 0

#--- ICMP Redirects
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.default.accept_redirects = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv4.conf.default.send_redirects = 0
net.ipv6.conf.all.accept_redirects = 0
net.ipv6.conf.default.accept_redirects = 0

#--- Reverse Path Filtering
net.ipv4.conf.all.rp_filter = 1
net.ipv4.conf.default.rp_filter = 1

#--- SYN Flood Protection
net.ipv4.tcp_syncookies = 1
net.ipv4.tcp_max_syn_backlog = 2048
net.ipv4.tcp_synack_retries = 2
net.ipv4.tcp_syn_retries = 5
```

FIGURE 34

```
#--- ICMP
net.ipv4.icmp_echo_ignore_broadcasts = 1
net.ipv4.icmp_ignore_bogus_error_responses = 1
net.ipv4.conf.all.log_martians = 1
net.ipv4.conf.default.log_martians = 1

#--- IPv6
net.ipv6.conf.all.disable_ipv6 = 1
net.ipv6.conf.default.disable_ipv6 = 1
net.ipv6.conf.lo.disable_ipv6 = 1
net.ipv6.conf.all.accept_ra = 0
net.ipv6.conf.default.accept_ra = 0

#--- Kernel Security
kernel.randomize_va_space = 2
kernel.dmesg_restrict = 1
kernel.yama.ptrace_scope = 1
kernel.kptr_restrict = 2
kernel.sysrq = 0
kernel.unprivileged_bpf_disabled = 1
net.core.bpf_jit_harden = 2

#--- Filesystem
fs.protected_symlinks = 1
fs.protected_hardlinks = 1
fs.protected_fifos = 2
fs.protected_regular = 2
fs.suid_dumpable = 0

#--- Virtual Memory
vm.overcommit_memory = 0
```

FIGURE 35

Pour finir, pour appliquer ces paramètres, nous avons utilisé la commande suivante : **sudo sysctl -system**.

```
* Applying /usr/lib/sysctl.d/10-apparmor.conf ...
* Applying /etc/sysctl.d/10-bufferbloat.conf ...
* Applying /etc/sysctl.d/10-console-messages.conf ...
* Applying /etc/sysctl.d/10-ipv6-privacy.conf ...
* Applying /etc/sysctl.d/10-kernel-hardening.conf ...
* Applying /etc/sysctl.d/10-magic-sysrq.conf ...
* Applying /etc/sysctl.d/10-map-count.conf ...
* Applying /etc/sysctl.d/10-network-security.conf ...
* Applying /etc/sysctl.d/10-ptrace.conf ...
* Applying /etc/sysctl.d/10-zero-page.conf ...
* Applying /usr/lib/sysctl.d/50-pid-max.conf ...
* Applying /etc/sysctl.d/99-hardening.conf ...
* Applying /usr/lib/sysctl.d/99-protect-links.conf ...
* Applying /etc/sysctl.d/99-sysctl.conf ...
* Applying /etc/sysctl.conf ...
```

FIGURE 36

4.1.4 Activation du firewall ufw

Par défaut, la distribution Ubuntu vient avec le firewall UFW (Uncomplicated Firewall) qui reste cependant désactivé. Toujours dans le processus de durcissement, nous avons défini les politiques par défaut qui refusent tout trafic entrant ou le forwarding, mais acceptent le trafic sortant via les commandes **sudo ufw default deny incoming**, **sudo ufw default allow outgoing**, **sudo ufw default deny forward**.

```
shinra@souleater:~$ which ufw
/usr/sbin/ufw
shinra@souleater:~$ sudo ufw default deny incoming
[sudo] password for shinra:
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
shinra@souleater:~$ sudo ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
shinra@souleater:~$ sudo ufw default deny forward
Default routed policy changed to 'deny'
(be sure to update your rules accordingly)
shinra@souleater:~$ _
```

FIGURE 37

Nous avons défini une whitelist de règles permettant d'accéder à certains services essentiels, à savoir le SSH, le HTTP ainsi que le FTP, à l'aide des commandes **sudo ufw allow 7777/tcp**, **sudo ufw allow 80/tcp**, **sudo ufw allow 21/tcp**.

```
shinra@souleater:~$ sudo ufw allow 7777/tcp comment "ssh"
[sudo] password for shinra:
Rules updated
Rules updated (v6)
shinra@souleater:~$ sudo ufw allow 80/tcp comment "http"
Rules updated
Rules updated (v6)
shinra@souleater:~$ sudo ufw allow 21/tcp comment "ftp"
Rules updated
Rules updated (v6)
shinra@souleater:~$ _
```

FIGURE 38

Nous avons par la suite activé notre firewall via la commande **sudo ufw enable** et pour visualiser les règles ainsi que le statut, nous avons enchaîné avec la commande **sudo ufw status verbose**.

```
shinra@souleater:~$ sudo ufw enable
[sudo] password for shinra:
Firewall is active and enabled on system startup
shinra@souleater:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
7777/tcp ALLOW IN Anywhere # ssh
80/tcp ALLOW IN Anywhere # http
21/tcp ALLOW IN Anywhere # ftp
7777/tcp (v6) ALLOW IN Anywhere (v6) # ssh
80/tcp (v6) ALLOW IN Anywhere (v6) # http
21/tcp (v6) ALLOW IN Anywhere (v6) # ftp

shinra@souleater:~$
```

FIGURE 39

Plus

UFW vient avec une fonctionnalité intégrée qui permet de stopper le brute-force SSH en utilisant la commande **sudo ufw limit <num_port_ssh>/tcp**.

Note

La version Pro d'Ubuntu permet d'utiliser le USG (Ubuntu Security Guide) qui permet d'automatiser le processus de durcissement et d'audits des systèmes Ubuntu pour être en conformité avec le **CIS Benchmark Compliance** ou le **DISA-STIG Compliance**.

4.1.5 Sécurisation GRUB

La prochaine étape consiste à sécuriser notre GRUB par un mot de passe, empêchant ainsi un attaquant ayant un accès physique de modifier les paramètres de démarrage, de booter en mode recovery sans mot de passe, ou de passer des arguments dangereux au noyau. Pour cela, nous allons tout d'abord créer un hash pour notre mot de passe via la commande `sudo grub-mkpasswd-pbkdf2`.

```
shinra@souleater:~$ sudo grub-mkpasswd-pbkdf2
Enter password:
Reenter password:
PBKDF2 hash of your password is grub.pbkdf2.sha512.10000.2F61
shinra@souleater:~$
```

FIGURE 40

Nous avons accédé au fichier **40-custom** de configuration du GRUB présent dans le dossier `/etc/grub.d`, dans lequel nous avons défini un utilisateur ainsi que le hash du mot de passe précédent pour forcer l'utilisation de ce dernier pour l'accès au GRUB.

```
#!/bin/sh
exec tail -n +3 $0
# This file provides an easy way to add custom menu entries. Simply type the
# menu entries you want to add after this comment. Be careful not to change
# the 'exec tail' line above.
set superusers="shinra"
password_pbkdf2 shinra grub.pbkdf2.sha512.10000.2F61
```

FIGURE 41

Afin de pouvoir effectuer un boot normal sans qu'à chaque fois on ait à mettre un mot de passe, nous avons ajouté l'instruction `--unrestricted` dans le fichier **10-linux**.

```
#
# You should have received a copy of the GNU General Public License
# along with GRUB. If not, see <http://www.gnu.org/licenses/>.

prefix="/usr"
exec_prefix="/usr"
datarootdir="/usr/share"
ubuntu_recovery="1"
quiet_boot="1"
quick_boot="1"
gfxpayload_dynamic="1"
vt_handoff="1"

. "$pkgdatadir/grub-mkconfig_lib"

export TEXTDOMAIN=grub
export TEXTDOMAINDIR="${datarootdir}/locale"

CLASS="--class gnu-linux --class gnu --class os --unrestricted"

if [ "x${GRUB_DISTRIBUTOR}" = "x" ] ; then
  OS=GNU/Linux
else
  case ${GRUB_DISTRIBUTOR} in
```

FIGURE 42

Pour finalement mettre à jour le GRUB avec les nouveaux paramètres, nous avons utilisé la commande **sudo update-grub**.

```
shinra@souleater:/etc/grub.d$ sudo update-grub
Sourcing file `/etc/default/grub'
Generating grub configuration file ...
Found linux image: /boot/vmlinuz-6.8.0-117-generic
Found initrd image: /boot/initrd.img-6.8.0-117-generic
Found linux image: /boot/vmlinuz-6.8.0-107-generic
Found initrd image: /boot/initrd.img-6.8.0-107-generic
Warning: os-prober will not be executed to detect other bootable partitions.
Systems on them will not be added to the GRUB boot configuration.
Check GRUB_DISABLE_OS_PROBER documentation entry.
Adding boot menu entry for UEFI Firmware Settings ...
done
shinra@souleater:/etc/grub.d$
```

FIGURE 43

4.1.6 Limitation accès root

L'accès direct au compte root doit être désactivé pour permettre aux administrations d'utiliser uniquement **sudo** ; cela crée une traçabilité et évite les accidents. Pour ce faire, nous avons utilisé la commande **sudo passwd -l root** pour verrouiller le mot de passe, empêchant toute connexion en tant qu'utilisateur root.

```
shinra@souleater:~$ sudo passwd -l root
passwd: password changed.
shinra@souleater:~$ cat /etc/shadow | grep root
cat: /etc/shadow: Permission denied
shinra@souleater:~$ sudo cat /etc/shadow | grep root
root:!*:19962:0:99999:7:::
shinra@souleater:~$
```

FIGURE 44

4.2 Sécurisation PAM

4.2.1 Expiration mot de passe

Nous avons modifié les règles d'expiration de mot de passe via le fichier `/etc/login.defs` dans lequel nous avons défini une durée maximale de 90 jours pendant lesquels le mot de passe peut être utilisé avant de devoir être changé, 2 jours d'intervalle sont permis entre les changements de mot de passe, et 14 jours avant l'expiration des avertissements seront émis. Ces règles seront appliquées sur tout nouvel utilisateur créé.

```
# HOME_MODE is used by useradd(8) and newusers(8) to set the mode for new
# home directories.
# If HOME_MODE is not set, the value of UMASK is used to create the mode.
HOME_MODE          0750

#
# Password aging controls:
#
#     PASS_MAX_DAYS   Maximum number of days a password may be used.
#     PASS_MIN_DAYS   Minimum number of days allowed between password changes.
#     PASS_WARN_AGE   Number of days warning given before a password expires.
#
PASS_MAX_DAYS      90
PASS_MIN_DAYS       2
PASS_WARN_AGE      14

#
# Min/max values for automatic uid selection in useradd
#
UID_MIN             1000
UID_MAX             60000
```

FIGURE 45

4.2.2 Complexité PAM

PAM est le framework d'authentification central d'Ubuntu. Pour imposer des règles de complexité, nous avons installé d'abord le module `pam_pwquality` via la commande `sudo apt install -y libpam-pwquality`. Par la suite, nous avons défini les règles au niveau du fichier `/etc/security/pwquality.conf`. Ce module sera appelé au niveau de `/etc/pam/common-password` pour être utilisé au niveau du système. Les spécifications requises sont illustrées ci-dessous :

```
# Minimum acceptable size for the new password (plus one if
# credits are not disabled which is the default). (See pam_cracklib manual.)
# Cannot be set to lower value than 6.
minlen = 12
#
# The maximum credit for having digits in the new password. If less than 0
# it is the minimum number of digits in the new password.
dcredit = -1
#
# The maximum credit for having uppercase characters in the new password.
# If less than 0 it is the minimum number of uppercase characters in the new
# password.
uccredit = -1
#
# The maximum credit for having lowercase characters in the new password.
# If less than 0 it is the minimum number of lowercase characters in the new
# password.
lccredit = -1
#
# The maximum credit for having other characters in the new password.
# If less than 0 it is the minimum number of other characters in the new
# password.
occredit = -1
#
# The minimum number of required classes of characters for the new
# password (digits, uppercase, lowercase, others).
minclass = 3
```

FIGURE 46

```
maxrepeat = 2
#
# The maximum number of allowed consecutive characters of the same class in the
# new password.
# The check is disabled if the value is 0.
maxclassrepeat = 4
#
# Whether to check for the words from the passwd entry GECOS string of the user.
# The check is enabled if the value is not 0.
gecoscheck = 0
#
# Whether to check for the words from the cracklib dictionary.
# The check is enabled if the value is not 0.
dictcheck = 1
#
# Whether to check if it contains the user name in some form.
# The check is enabled if the value is not 0.
usercheck = 1
#
# Length of substrings from the username to check for in the password
# The check is enabled if the value is greater than 0 and usercheck is enabled.
# usersubstr = 0
#
# Whether the check is enforced by the PAM module and possibly other
# applications.
# The new password is rejected if it fails the check and the value is not 0.
# enforcing = 1
#
# Path to the cracklib dictionaries. Default is to use the cracklib default.
# dictpath =
#
# Prompt user at most N times before returning with error. The default is 1.
# retry = 3
#
```

FIGURE 47

Ainsi, chaque mot de passe doit avoir :

- au minimum 12 caractères
- au moins 1 chiffre
- au moins une lettre majuscule
- au moins une lettre minuscule
- au moins un caractère spécial
- au moins 3 des classes doivent apparaître (majuscule, minuscule, chiffre, caractère spécial)
- un caractère ne peut être répété que 3 fois consécutivement
- des éléments d'une même classe ne peuvent être répétés que 4 fois consécutivement
- différent du nom d'utilisateur

Le prompt demandant le mot de passe retournera une erreur après 3 tentatives échouées.

4.2.3 Verrouillage tentative

Afin d'assurer le verrouillage après plusieurs tentatives échouées, nous avons défini ces paramètres au niveau du fichier `/etc/security/faillock.conf`. Ainsi, après 5 tentatives erronées en l'espace de 15 minutes, le compte sera bloqué pour une période de 10 minutes.

```
# Deny access if the number of consecutive authentication failures
# for this user during the recent interval exceeds n tries.
# The default is 3.
deny = 5
#
# The length of the interval during which the consecutive
# authentication failures must happen for the user account
# lock out is <replaceable>n</replaceable> seconds.
# The default is 900 (15 minutes).
fail_interval = 900
#
# The access will be re-enabled after n seconds after the lock out.
# The value 0 has the same meaning as value `never` - the access
# will not be re-enabled without resetting the faillock
# entries by the `faillock` command.
# The default is 600 (10 minutes).
unlock_time = 600
#
# Root account can become locked as well as regular accounts.
```

FIGURE 48

Afin que les règles puissent être utilisées au niveau du système, nous avons inséré une ligne qui fait appel au module `pam_faillock` au sein du fichier `/etc/pam.d/common-auth`, de même pour le fichier `/etc/pam.d/common-account`.

```
# This file is included from other service-specific PAM config files,
# and should contain a list of the authentication modules that define
# the central authentication scheme for use on the system
# (e.g., /etc/shadow, LDAP, Kerberos, etc.). The default is to use the
# traditional Unix authentication mechanisms.
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules. See
# pam-auth-update(8) for details.
#
# here are the per-package modules (the "Primary" block)
auth      required      pam_faillock.so_
auth      [success=1 default=ignore] pam_unix.so nullok
# here's the fallback if no module succeeds
auth      requisite     pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just turn around
```

FIGURE 49

4.3 Sécurisation SSH

4.3.1 Génération des clés

La première étape pour sécuriser le SSH est de mettre en place l'authentification via une clé au lieu d'un mot de passe. Mais avant de configurer cela, nous avons en premier lieu généré les clés au niveau du client (laptop de l'admin) via la commande **ssh-keygen -t ed25519 -C "shinra"**. L'option **-C** permet d'ajouter un commentaire.

```
mint@mintos:~$ ssh-keygen -t ed25519 -C "shinra"
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/mint/.ssh/id_ed25519):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/mint/.ssh/id_ed25519
Your public key has been saved in /home/mint/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:6ioJkF1Ci3WMnPNqEWBPu0664ZiFhXwJ/ngQavRnT/0 shinra
The key's randomart image is:
+--[ED25519 256]--+
|.0=.
|.oXo+
|.*.0
|B.* + .
|+=.0 o .S.
|oo@ o o. .
|.*.= .. E
|oo* .
|oo ....
+-----[SHA256]-----+
```

FIGURE 50

Par la suite, nous avons copié la clé publique sur le serveur Ubuntu via la commande **ssh-copy-id shinra@192.168.10.10**.

```
mint@mintos:~$ ssh-copy-id shinra@192.168.10.10
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new keys
shinra@192.168.10.10's password:

Number of key(s) added: 1

Now try logging into the machine, with:  "ssh 'shinra@192.168.10.10'"
and check to make sure that only the key(s) you wanted were added.
```

FIGURE 51

Note

Pour faire la copie de la clé publique sur le serveur, il a fallu ajouter une règle au niveau du firewall UFW pour permettre le trafic entrant au niveau du port 22 temporairement.

4.3.2 Configuration générale de sshd_config

Afin de pouvoir permettre l'authentification par clé, désactiver le root login ainsi que limiter les tentatives, nous avons d'abord fait une copie du fichier via la commande **sudo cp /etc/ssh/sshd_config /etc/ssh/sshd_config.backup**. Par la suite, nous avons configuré notre fichier **/etc/ssh/sshd_config** comme suit :

```
#
Port 7777
AddressFamily inet
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
SyslogFacility AUTH
LogLevel VERBOSE

# Authentication:
#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
MaxAuthTries 3
MaxSessions 5

PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
AuthorizedKeysFile .ssh/authorized_keys

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication no
PermitEmptyPasswords no
```

FIGURE 52

```
# some PAM modules and threads)
KbdInteractiveAuthentication no

# Kerberos options
#KerberosAuthentication no
#KerberosOrLocalPasswd yes
#KerberosTicketCleanup yes
#KerberosGetAFSToken no

# GSSAPI options
#GSSAPIAuthentication no
#GSSAPICleanupCredentials yes
#GSSAPIStrictAcceptorCheck yes
#GSSAPIKeyExchange no

# Set this to 'yes' to enable PAM authentication, account processing,
# and session processing. If this is enabled, PAM authentication will
# be allowed through the KbdInteractiveAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via KbdInteractiveAuthentication may bypass
# the setting of "PermitRootLogin prohibit-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and KbdInteractiveAuthentication to 'no'.
UsePAM yes

#AllowAgentForwarding yes
#AllowTcpForwarding yes
#GatewayPorts no
X11Forwarding yes
#X11DisplayOffset 10
#X11UseLocalhost yes
#PermitTTY yes
PrintMotd no
#PrintLastLog yes
#TCPKeepAlive yes
#PermitUserEnvironment no
#Compression delayed
#ClientAliveInterval 0
#ClientAliveCountMax 3
#UseDNS no
#PidFile /run/sshd.pid
#MaxStartups 10:30:100
#PermitTunnel no
#ChrootDirectory none
#VersionAddendum none

# no default banner path
Banner /etc/ssh/banner.txt
```

FIGURE 53

Nous avons inscrit le message qui apparaîtra au niveau de la bannière comme suit :

```
GNU nano 7.2 /etc/ssh/banner.txt
#####
#  ACCES AUTORISE UNIQUEMENT
#  Toute connexion est enregistrée et
#  susceptible de poursuites legales :)
#####_
```

FIGURE 54

Pour permettre à ce que les changements apportés sur le service SSH puissent prendre effet, nous avons exécuté sur le terminal les commandes suivantes, à savoir : **sudo systemctl daemon-reload** et **sudo systemctl restart ssh.socket**.

5 Services sur Ubuntu Server

• Apache 2

```
shinra@souleater:~$ sudo systemctl status apache2
• apache2.service - The Apache HTTP Server
  Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: enabled)
  Active: active (running) since Tue 2026-05-26 11:50:17 UTC; 2h 19min ago
  Docs: https://httpd.apache.org/docs/2.4/
  Main PID: 941 (apache2)
  Tasks: 55 (limit: 2263)
  Memory: 7.8M (peak: 8.0M)
  CPU: 546ms
  CGroup: /system.slice/apache2.service
          └─941 /usr/sbin/apache2 -k start
            └─945 /usr/sbin/apache2 -k start
              └─946 /usr/sbin/apache2 -k start

May 26 11:50:05 souleater systemd[1]: Starting apache2.service - The Apache HTTP Server...
```

FIGURE 55

• OpenSSH

```
shinra@souleater:~$ sudo systemctl status ssh
• ssh.service - OpenBSD Secure Shell server
  Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: enabled)
  Active: active (running) since Tue 2026-05-26 13:59:35 UTC; 10min ago
  TriggeredBy: • ssh.socket
  Docs: man:sshd(8)
        man:sshd_config(5)
  Process: 2145 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
  Main PID: 2147 (sshd)
  Tasks: 1 (limit: 2263)
  Memory: 1.2M (peak: 3.8M)
  CPU: 91ms
  CGroup: /system.slice/ssh.service
          └─2147 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

May 26 13:59:35 souleater systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
```

FIGURE 56

• FTP

```
shinra@souleater:~$ sudo systemctl status vsftpd
• vsftpd.service - vsftpd FTP server
  Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; enabled; preset: enabled)
  Active: active (running) since Tue 2026-05-26 11:50:03 UTC; 2h 20min ago
  Main PID: 841 (vsftpd)
  Tasks: 1 (limit: 2263)
  Memory: 932.0K (peak: 1.4M)
  CPU: 14ms
  CGroup: /system.slice/vsftpd.service
          └─841 /usr/sbin/vsftpd /etc/vsftpd.conf

May 26 11:50:03 souleater systemd[1]: Starting vsftpd.service - vsftpd FTP server...
```

FIGURE 57

6 Déploiement IDS/IPS

6.1 Installation Suricata

Pour installer Suricata, nous avons accédé au tableau de bord (dashboard) de notre pfSense, par la suite nous avons cliqué sur le menu déroulant **System**, puis nous avons accédé au Package Manager et tapé au niveau de la barre de recherche "**suricata**", pour finir nous avons cliqué sur installer.

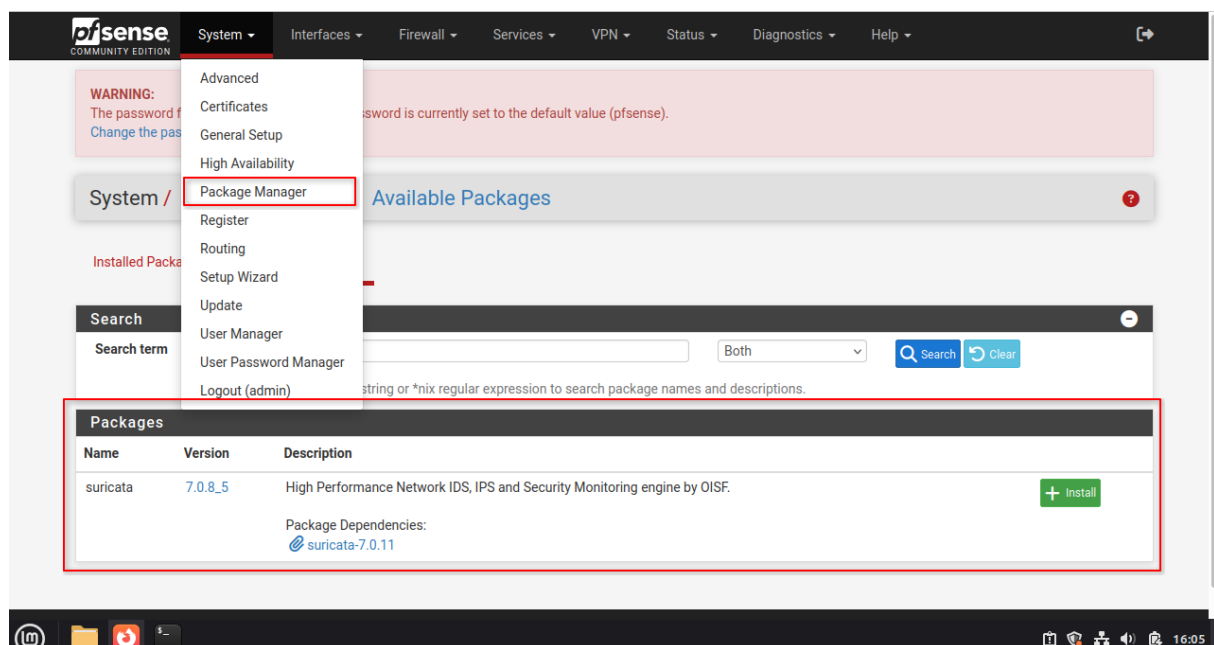


FIGURE 58

6.2 Configuration des paramètres globaux

Une fois installé, nous avons accédé au menu **"Services"** pour choisir Suricata afin de pouvoir accéder à ses paramètres de configuration. Nous avons accédé aux **Global Settings** dans lesquels nous avons sélectionné certains paramètres.

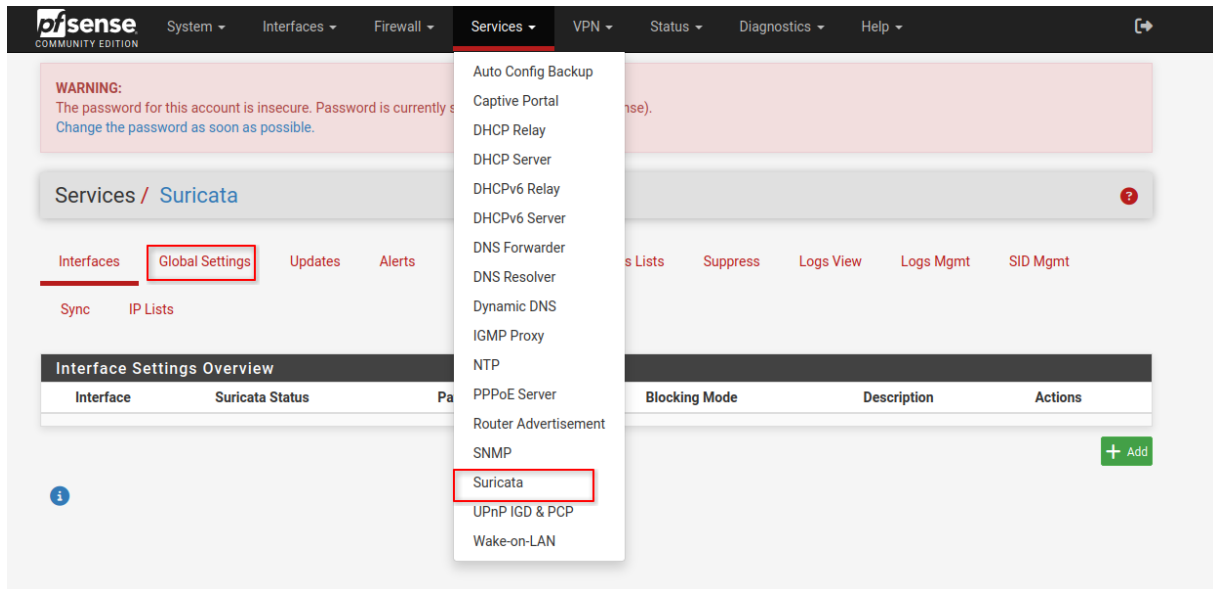


FIGURE 59

Nous avons permis à ce que Suricata puisse utiliser un ensemble de règles déjà prédéfinies venant d'ETOpen ainsi que Snort GPLv2 Community.

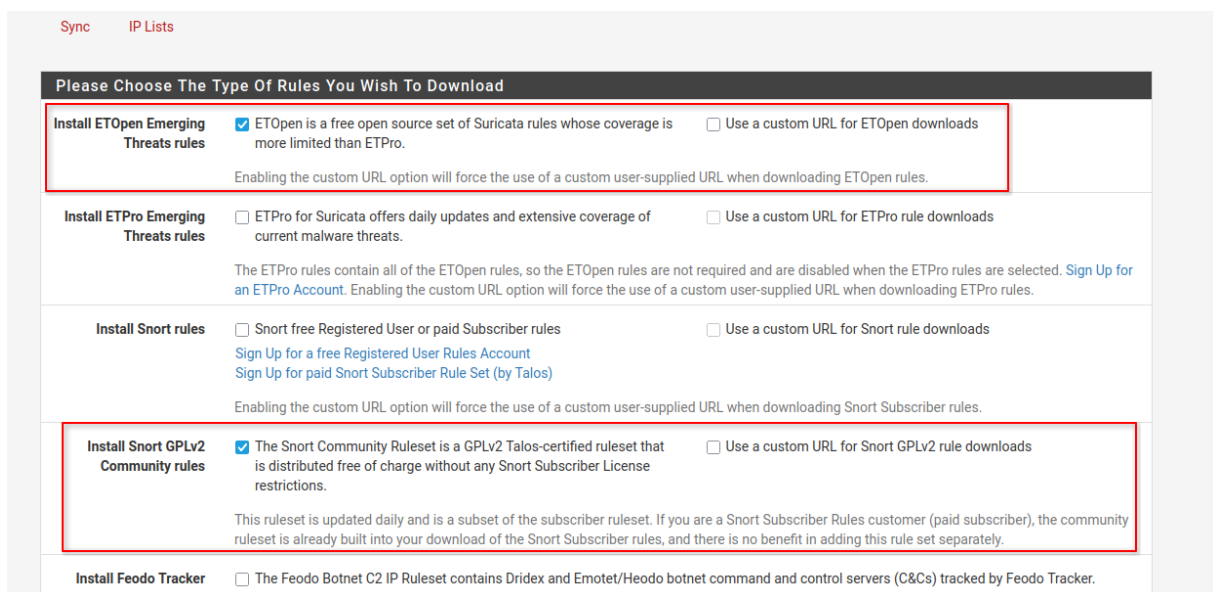
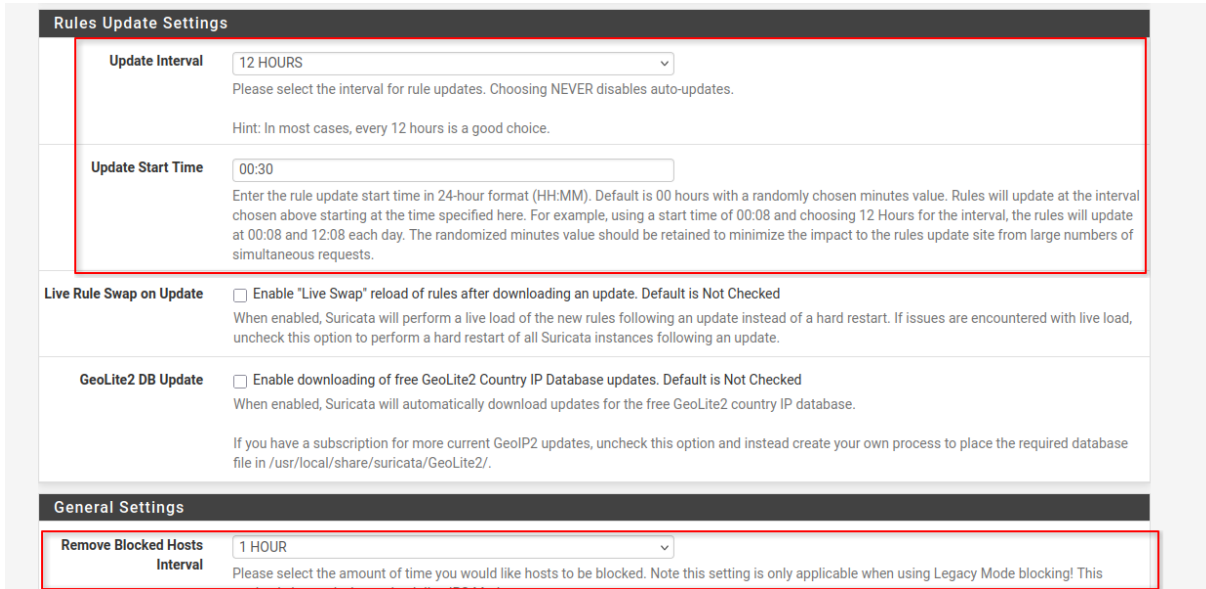


FIGURE 60

Nous avons défini aussi les intervalles de mise à jour des règles ainsi que l'heure à laquelle commenceront les mises à jour. Nous avons défini une durée de 1 heure pour les hôtes bloqués.



Rules Update Settings

Update Interval 12 HOURS
Please select the interval for rule updates. Choosing NEVER disables auto-updates.
Hint: In most cases, every 12 hours is a good choice.

Update Start Time 00:30
Enter the rule update start time in 24-hour format (HH:MM). Default is 00 hours with a randomly chosen minutes value. Rules will update at the interval chosen above starting at the time specified here. For example, using a start time of 00:08 and choosing 12 Hours for the interval, the rules will update at 00:08 and 12:08 each day. The randomized minutes value should be retained to minimize the impact to the rules update site from large numbers of simultaneous requests.

Live Rule Swap on Update ☐ Enable "Live Swap" reload of rules after downloading an update. Default is Not Checked
When enabled, Suricata will perform a live load of the new rules following an update instead of a hard restart. If issues are encountered with live load, uncheck this option to perform a hard restart of all Suricata instances following an update.

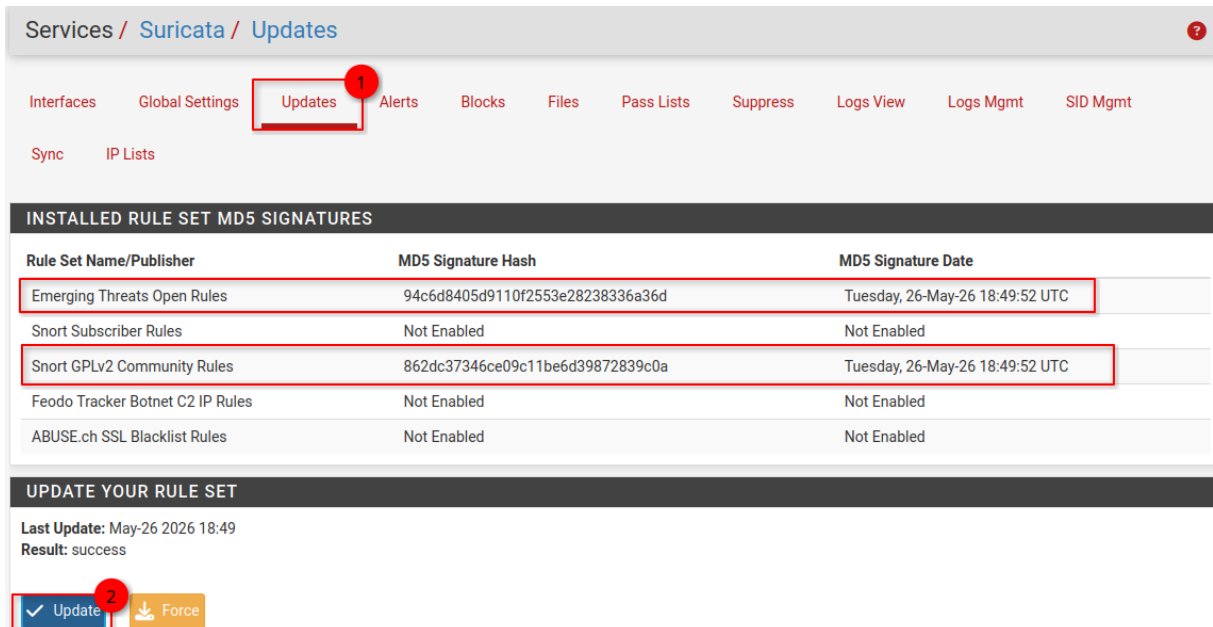
GeoLite2 DB Update ☐ Enable downloading of free GeoLite2 Country IP Database updates. Default is Not Checked
When enabled, Suricata will automatically download updates for the free GeoLite2 country IP database.
If you have a subscription for more current GeoIP2 updates, uncheck this option and instead create your own process to place the required database file in /usr/local/share/suricata/GeoLite2/.

General Settings

Remove Blocked Hosts Interval 1 HOUR
Please select the amount of time you would like hosts to be blocked. Note this setting is only applicable when using Legacy Mode blocking! This

FIGURE 61

Pour mettre à jour les règles cochées, nous avons accédé à la partie **Update** afin de pouvoir faire cela.



Services / Suricata / Updates

Interfaces Global Settings **Updates** Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

INSTALLED RULE SET MD5 SIGNATURES

Rule Set Name/Publisher	MD5 Signature Hash	MD5 Signature Date
Emerging Threats Open Rules	94c6d8405d9110f2553e28238336a36d	Tuesday, 26-May-26 18:49:52 UTC
Snort Subscriber Rules	Not Enabled	Not Enabled
Snort GPLv2 Community Rules	862dc37346ce09c11be6d39872839c0a	Tuesday, 26-May-26 18:49:52 UTC
Feodo Tracker Botnet C2 IP Rules	Not Enabled	Not Enabled
ABUSE.ch SSL Blacklist Rules	Not Enabled	Not Enabled

UPDATE YOUR RULE SET

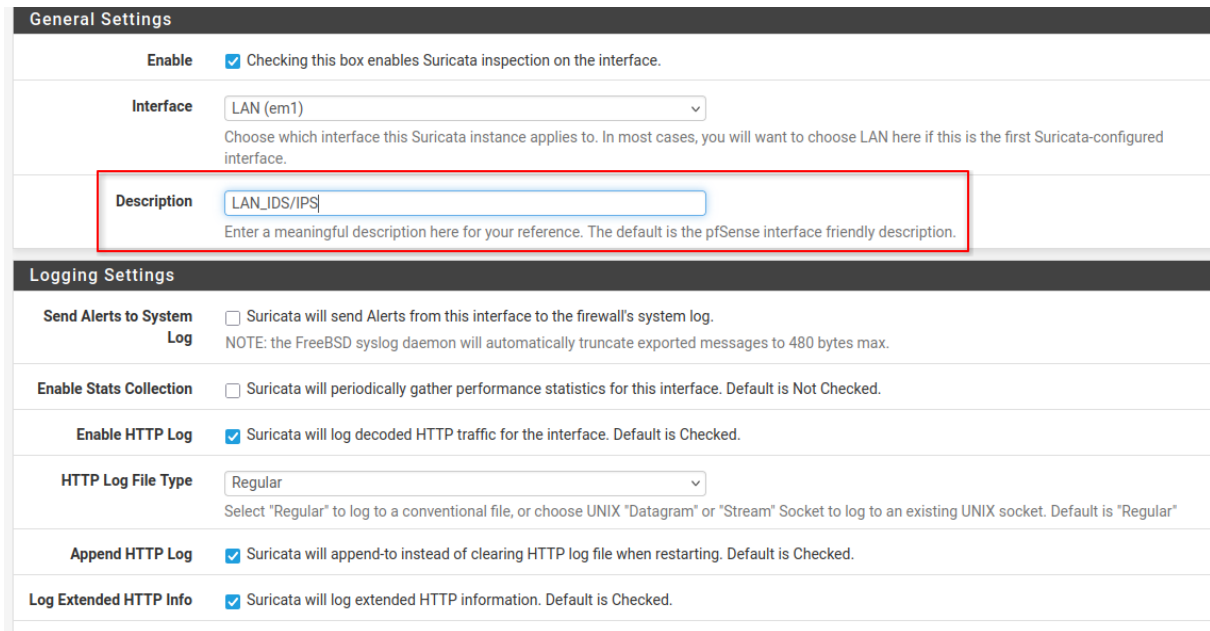
Last Update: May-26 2026 18:49
Result: success

Update Force

FIGURE 62

6.3 Activation IDS

Pour activer la journalisation, nous avons accédé à la section **Interfaces** dans laquelle nous avons cliqué sur **Add** pour ajouter l'interface. Nous avons configuré l'interface LAN puis un nom de description, le reste des paramètres étant laissé à sa valeur par défaut. Cela permet à Suricata de jouer son rôle d'IDS en analysant le trafic entrant et sortant au niveau de l'interface tout en levant des alertes si le trafic correspond à une des règles de menaces.

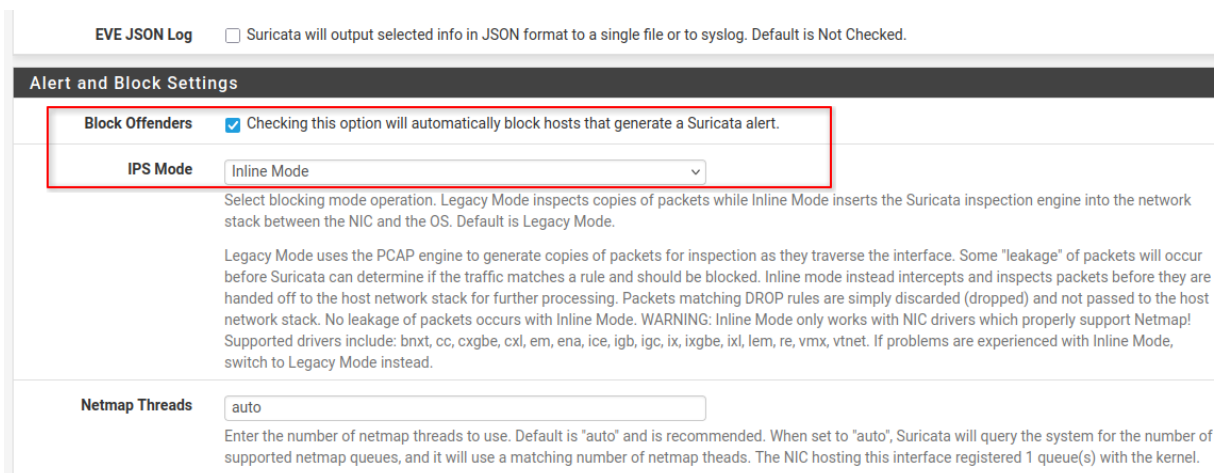


The screenshot shows the configuration interface for Suricata. The **General Settings** section includes an **Enable** checkbox (checked) and an **Interface** dropdown menu set to **LAN (em1)**. The **Description** field is highlighted with a red box and contains the text **LAN_IDS/IPS**. Below this, the **Logging Settings** section is visible, showing options for **Send Alerts to System Log**, **Enable Stats Collection**, **Enable HTTP Log**, **HTTP Log File Type**, **Append HTTP Log**, and **Log Extended HTTP Info**.

FIGURE 63

6.4 Activation IPS inline mode

Contrairement à l'IDS, l'IPS peut agir en conséquence en bloquant l'hôte, c'est là que réside la différence. Pour cela, il suffit de défiler en bas, de cocher la case **Block Offenders** et de sélectionner le mode **inline**. Puis à la fin, on clique sur **Save**.



The screenshot shows the **Alert and Block Settings** section of the configuration interface. The **Block Offenders** checkbox is checked. The **IPS Mode** dropdown menu is highlighted with a red box and set to **Inline Mode**. Below this, the **Netmap Threads** field is visible, set to **auto**.

FIGURE 64

6.5 Configuration Détection

Pour configurer les détections, on double-clique sur notre interface créée pour par la suite accéder à la section **LAN Categories** où nous avons choisi les catégories de règles qui seront utilisées.

☐	files.rules	☐	emerging-chat.rules
☒	ftp-events.rules	☐	emerging-ciarmy.rules
☒	http-events.rules	☐	emerging-coinminer.rules
☐	http2-events.rules	☐	emerging-compromised.rules
☐	ipsec-events.rules	☐	emerging-current_events.rules
☐	kerberos-events.rules	☐	emerging-deleted.rules
☐	modbus-events.rules	☐	emerging-dns.rules
☐	mqtt-events.rules	☒	emerging-dos.rules
☐	nfs-events.rules	☐	emerging-drop.rules
☐	ntp-events.rules	☐	emerging-dshield.rules
☐	quic-events.rules	☐	emerging-dyn_dns.rules
☐	rfb-events.rules	☒	emerging-exploit.rules
☐	smb-events.rules	☐	emerging-exploit_kit.rules
☐	smtp-events.rules	☐	emerging-file_sharing.rules
☒	ssh-events.rules	☒	emerging-ftp.rules
☐	stream-events.rules	☐	emerging-games.rules
☐	tls-events.rules	☐	emerging-hunting.rules
		☒	emerging-icmp.rules

FIGURE 65

☐	emerging-retired.rules
☐	emerging-rpc.rules
☐	emerging-scada.rules
☒	emerging-scan.rules
☒	emerging-shellcode.rules
☐	emerging-smtp.rules
☐	emerging-snmp.rules
☐	emerging-sql.rules

FIGURE 66

7 Attaques Kali Linux

- Scan Réseau

```
(kali㉿kali)-[~]  
$ nmap -sS 192.168.10.10  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-27 11:17 -0400  
Nmap scan report for 192.168.10.10 (192.168.10.10)  
Host is up (0.0013s latency).  
All 1000 scanned ports on 192.168.10.10 (192.168.10.10) are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Nmap done: 1 IP address (1 host up) scanned in 25.46 seconds
```

FIGURE 67

- Détection des Services

```
(kali㉿kali)-[~]  
$ nmap -sV 192.168.10.10  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-27 11:19 -0400  
Nmap scan report for 192.168.10.10 (192.168.10.10)  
Host is up (0.0021s latency).  
All 1000 scanned ports on 192.168.10.10 (192.168.10.10) are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 22.65 seconds
```

FIGURE 68

- Brute Force SSH

```
(kali㉿kali)-[~]  
$ sudo hydra -l user -P /usr/share/wordlists/rockyou.txt ssh://192.168.10.10 -s 7777  
[sudo] password for kali:  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or  
for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-26 21:08:36  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task  
[DATA] attacking ssh://192.168.10.10:7777/  
[STATUS] 172.00 tries/min, 172 tries in 00:01h, 14344230 to do in 1389:57h, 13 active  
  
[STATUS] 161.67 tries/min, 485 tries in 00:03h, 14343917 to do in 1478:46h, 13 active  
[STATUS] 152.71 tries/min, 1069 tries in 00:07h, 14343335 to do in 1565:23h, 11 active
```

FIGURE 69

- Ping Flood

```
(kali㉿kali)-[~]  
$ sudo ping -f 192.168.10.10  
[sudo] password for kali:  
PING 192.168.10.10 (192.168.10.10) 56(84) bytes of data.  
.^C  
— 192.168.10.10 ping statistics —  
53200 packets transmitted, 53199 received, 0.0018797% packet loss, time 29825ms  
rtt min/avg/max/mdev = 0.271/0.521/6.291/0.188 ms, ipg/ewma 0.560/0.427 ms
```

FIGURE 70

• Logs

250

Alert Log View Filter										
Last 250 Alert Entries. (Most recent entries are listed first)										
Note: Alerts triggered by DROP rules that resulted in dropped (blocked) packets are shown with highlighted rows below.										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
05/27/2026 14:32:56		3	TCP	Detection of a Network Scan	192.168.11.116	42373	192.168.10.10	109	1:9000001	Nmap SYN Scan
05/27/2026 14:32:56		3	TCP	Detection of a Network Scan	192.168.11.116	42373	192.168.10.10	1075	1:9000001	Nmap SYN Scan
05/27/2026 14:32:56		3	TCP	Detection of a Network Scan	192.168.11.116	42373	192.168.10.10	8011	1:9000001	Nmap SYN Scan
05/27/2026 14:32:56		3	TCP	Detection of a Network Scan	192.168.11.116	42380	192.168.10.10	80	1:9000001	Nmap SYN Scan
05/27/2026 14:32:56		3	TCP	Detection of a Network Scan	192.168.11.116	42371	192.168.10.10	5911	1:9000001	Nmap SYN Scan
05/27/2026 14:32:56		3	TCP	Detection of a Network Scan	192.168.11.116	42371	192.168.10.10	1033	1:9000001	Nmap SYN Scan
05/27/2026 14:32:56		3	TCP	Detection of a Network Scan	192.168.11.116	42371	192.168.10.10	31038	1:9000001	Nmap SYN Scan

FIGURE 71

05/27/2026 14:53:48		3	TCP	Detection of a Network Scan	192.168.11.116	58474	192.168.10.10	7777	1:9000002	Nmap Service Version Scan
05/27/2026 14:36:41		1	TCP	Web Application Attack	192.168.11.116	59398	192.168.10.10	80	1:2009358	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
05/27/2026 14:36:41		1	TCP	Web Application Attack	192.168.11.116	59396	192.168.10.10	80	1:2009358	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
05/27/2026 14:36:41		1	TCP	Web Application Attack	192.168.11.116	59388	192.168.10.10	80	1:2009358	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)
05/27/2026 14:36:41		1	TCP	Web Application Attack	192.168.11.116	59366	192.168.10.10	80	1:2009358	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)

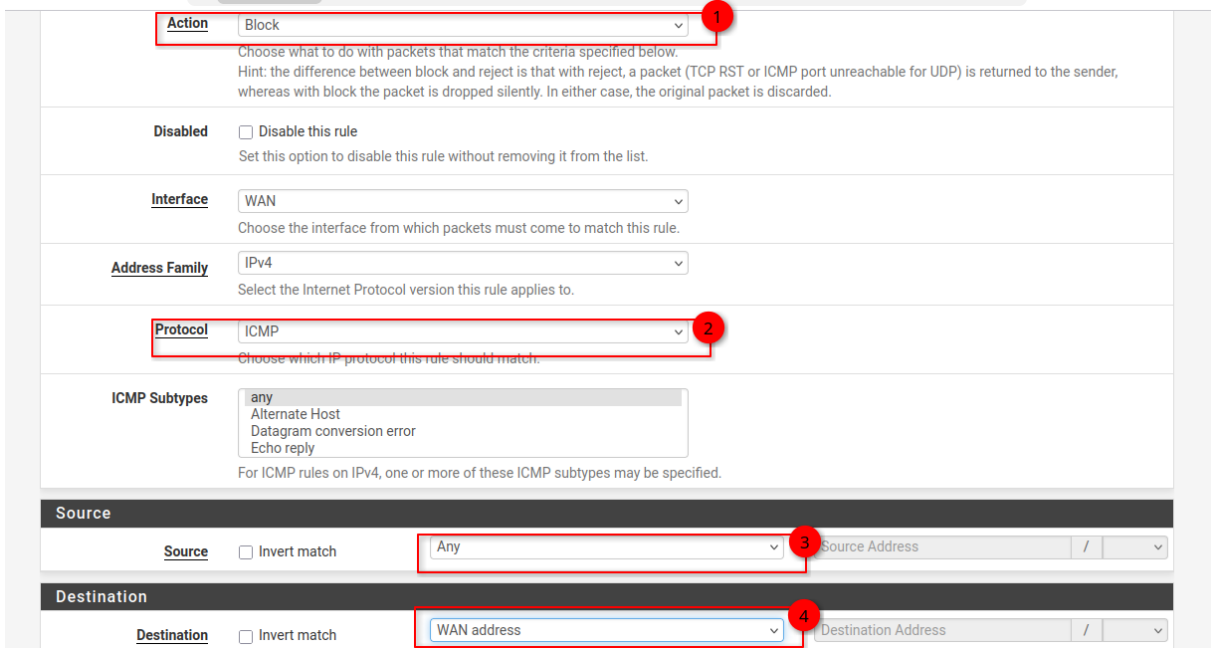
FIGURE 72

05/27/2026 15:28:35		1	TCP	Attempted User Privilege Gain	192.168.11.116	55878	192.168.10.10	7777	1:9000003	Brute Force SSH
05/27/2026 15:28:35		3	TCP	Detection of a Network Scan	192.168.11.116	55948	192.168.10.10	7777	1:9000002	Nmap Service Version Scan
05/27/2026 15:17:21		3	ICMP	Misc activity	192.168.11.116	8	192.168.10.10	0	1:2100366	GPL ICMP PING *NIX
05/27/2026 15:17:21		3	ICMP	Misc activity	192.168.11.116	8	192.168.10.10	0	1:2100366	GPL ICMP PING *NIX
05/27/2026 15:17:21		3	ICMP	Misc activity	192.168.11.116	8	192.168.10.10	0	1:2100366	GPL ICMP PING *NIX
05/27/2026 15:17:21		3	ICMP	Misc activity	192.168.11.116	8	192.168.10.10	0	1:2100366	GPL ICMP PING *NIX
05/27/2026 15:17:21		3	ICMP	Misc activity	192.168.11.116	8	192.168.10.10	0	1:2100366	GPL ICMP PING *NIX
05/27/2026 15:17:21		3	ICMP	Misc activity	192.168.11.116	8	192.168.10.10	0	1:2100366	GPL ICMP PING *NIX

FIGURE 73

8 Firewalling

En premier lieu, nous avons bloqué les paquets ICMP. Pour cela, nous avons accédé à la section **Rules** du menu **Firewall**, puis la partie WAN. Nous avons ajouté une nouvelle règle comme suit.



Action Block

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface WAN
Choose the interface from which packets must come to match this rule.

Address Family IPv4
Select the Internet Protocol version this rule applies to.

Protocol ICMP
Choose which IP protocol this rule should match.

ICMP Subtypes any
Alternate Host
Datagram conversion error
Echo reply
For ICMP rules on IPv4, one or more of these ICMP subtypes may be specified.

Source

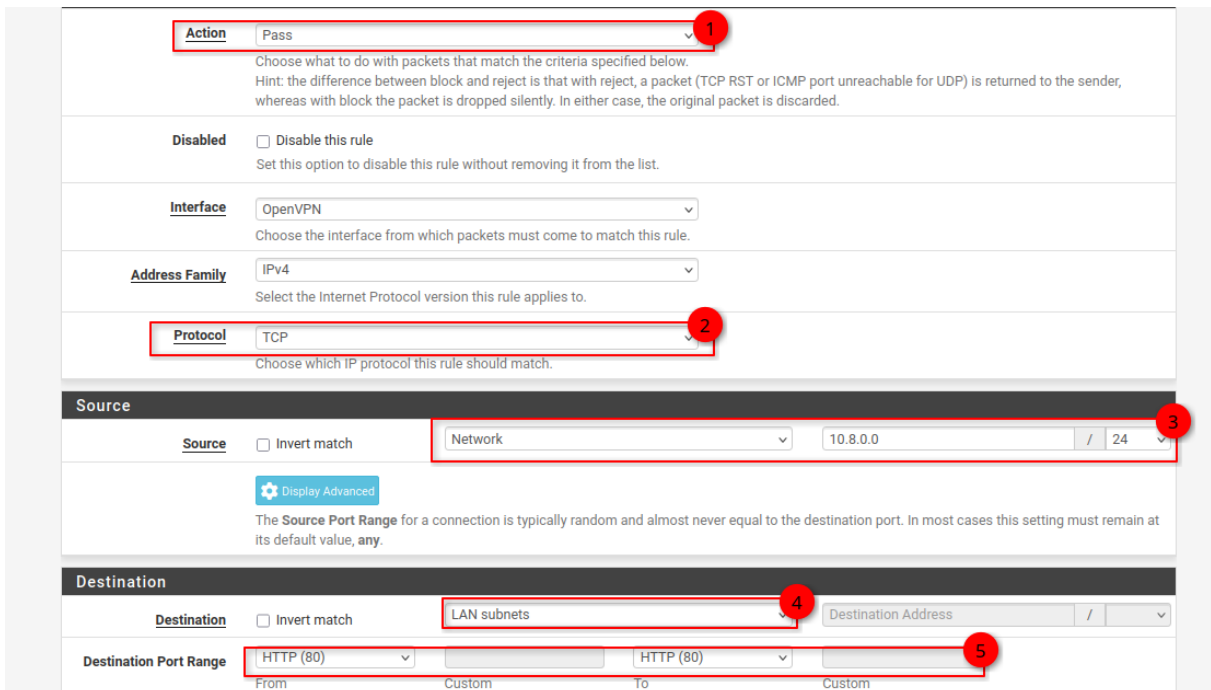
Source ☐ Invert match Any Source Address /

Destination

Destination ☐ Invert match WAN address Destination Address /

FIGURE 74

Toujours dans la même section, nous avons accédé à l'interface OpenVPN dans laquelle nous avons défini la règle pour permettre uniquement le trafic HTTP.



Action Pass

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface OpenVPN
Choose the interface from which packets must come to match this rule.

Address Family IPv4
Select the Internet Protocol version this rule applies to.

Protocol TCP
Choose which IP protocol this rule should match.

Source

Source ☐ Invert match Network 10.8.0.0 / 24

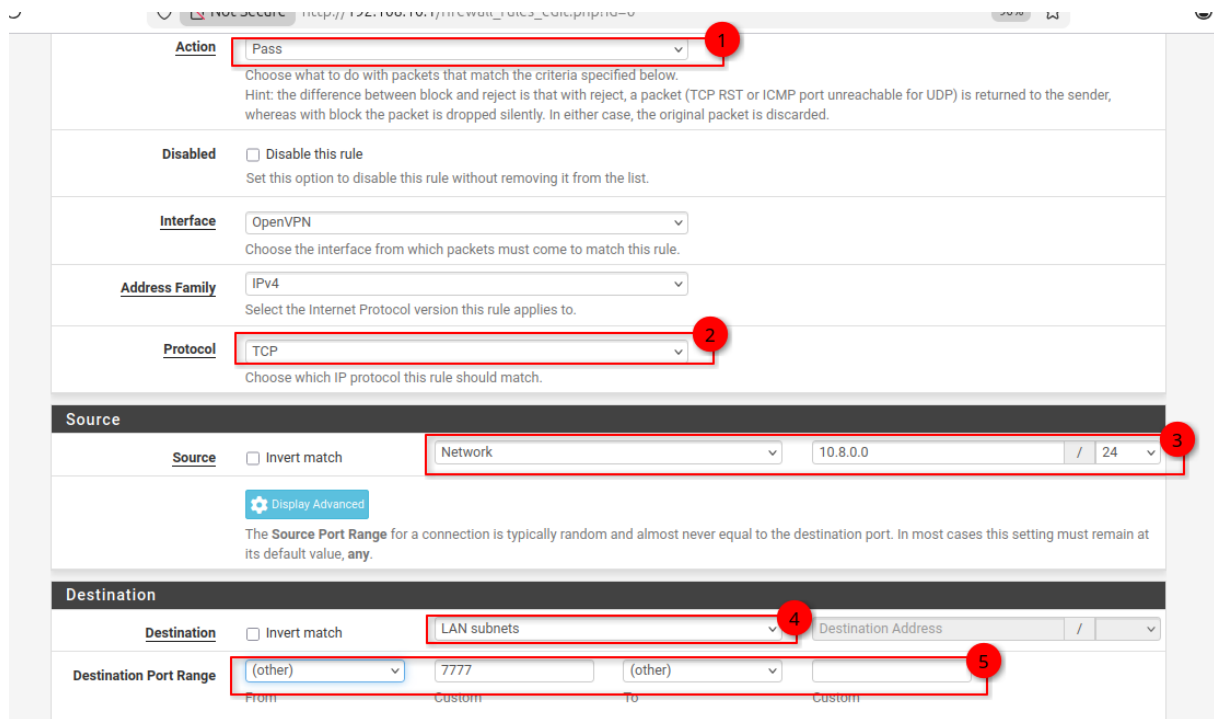
Destination

Destination ☐ Invert match LAN subnets Destination Address /

Destination Port Range HTTP (80) From Custom To Custom

FIGURE 75

Nous avons fait de même pour permettre aussi uniquement le trafic SSH via ce tunnel.

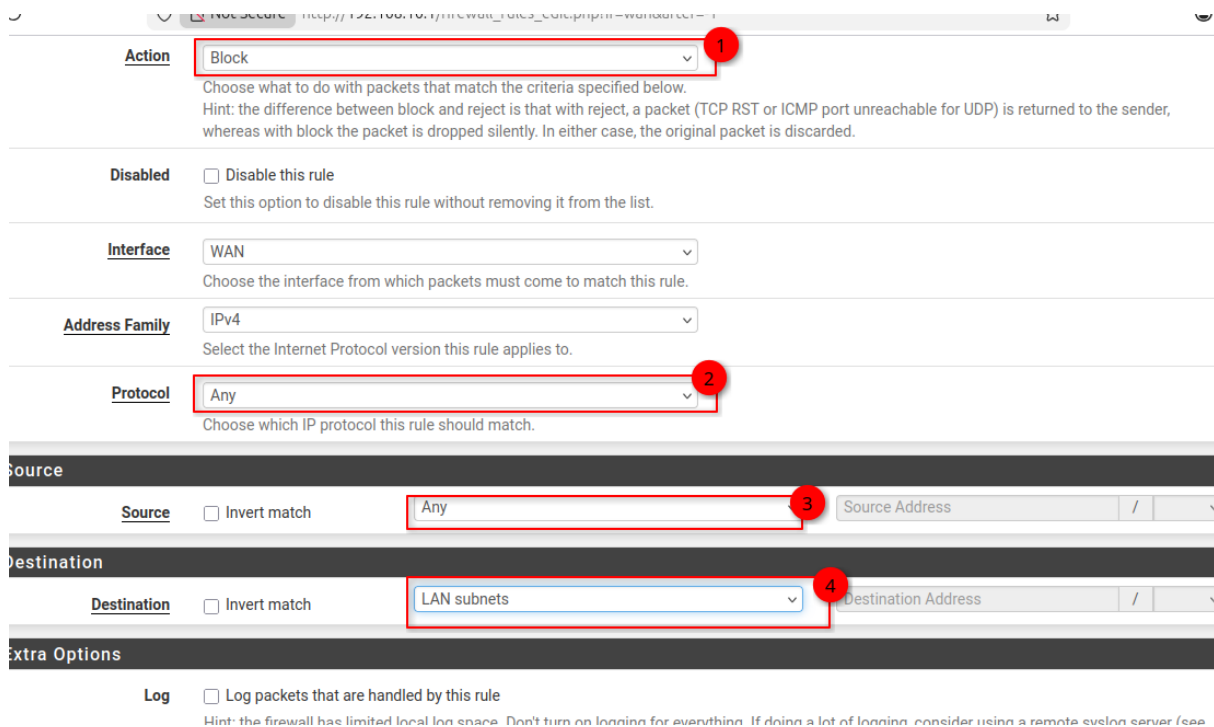


The screenshot shows the configuration of a firewall rule in pfSense. The rule is named "OpenVPN Tunnel Traffic". The configuration is as follows:

- Action:** Pass (indicated by a red box and number 1).
- Disabled:** ☐ Disable this rule.
- Interface:** OpenVPN (indicated by a red box and number 2).
- Address Family:** IPv4.
- Protocol:** TCP (indicated by a red box and number 3).
- Source:**
 - Source:** ☐ Invert match. Network: 10.8.0.0 / 24 (indicated by a red box and number 4).
- Destination:**
 - Destination:** ☐ Invert match. LAN subnets (indicated by a red box and number 5).
 - Destination Port Range:** (other) 7777 (other) (indicated by a red box and number 6).

FIGURE 76

Afin de parer les attaques issues de Kali, nous avons défini une règle au niveau du pare-feu qui va empêcher tout trafic externe entrant en direction du LAN.



The screenshot shows the configuration of a firewall rule in pfSense. The rule is named "Block External Traffic to LAN". The configuration is as follows:

- Action:** Block (indicated by a red box and number 1).
- Disabled:** ☐ Disable this rule.
- Interface:** WAN (indicated by a red box and number 2).
- Address Family:** IPv4.
- Protocol:** Any (indicated by a red box and number 3).
- Source:**
 - Source:** ☐ Invert match. Any (indicated by a red box and number 4).
- Destination:**
 - Destination:** ☐ Invert match. LAN subnets (indicated by a red box and number 5).
- Extra Options:**
 - Log:** ☐ Log packets that are handled by this rule.

FIGURE 77

9 Références

- Canonical. (s. d.-a). *Ubuntu Security Documentation : Compliance*.
<https://documentation.ubuntu.com/security/compliance/>
- Canonical. (s. d.-b). *Ubuntu Security Documentation : Security features*.
<https://documentation.ubuntu.com/security/security-features/>
- Canonical. (s. d.-c). *Ubuntu Server documentation : Explanations*.
<https://ubuntu.com/server/docs/explanation/>
- Canonical. (s. d.-d). *Ubuntu Server documentation : How-to guides*.
<https://ubuntu.com/server/docs/how-to/>
- Center for Internet Security (CIS). (s. d.). *CIS Ubuntu Linux Benchmarks*.
https://www.cisecurity.org/benchmark/ubuntu_linux
- OneUptime Blog. (2026, 2 mars). *How to harden Ubuntu kernel with sysctl settings*.
<https://oneuptime.com/blog/post/2026-03-02-how-to-harden-ubuntu-kernel-with-sysctl-settings>
- Seth-Enoka. (2023). *Cybersecurity for small Enterprise*. No Starch Press.
- The Linux Kernel Organization. (s. d.). *The Linux Kernel User's and Administrator's Guide*.
<https://www.kernel.org/doc/html/latest/admin-guide/index.html>
- Netgate. (s. d.-e). *pfSense Documentation*.
<https://docs.netgate.com/pfsense/en/latest/>
- OpenSSH. (s. d.). *OpenSSH Manual*.
<https://www.openssh.com/manual.html>
- Lawrence Systems (Youtube). *Suricata Network IDS/IPS Installation, Setup, and How To Tune The Rules & Alerts on pfSense 2020*.
<https://youtu.be/S0-vsjhPDN0>